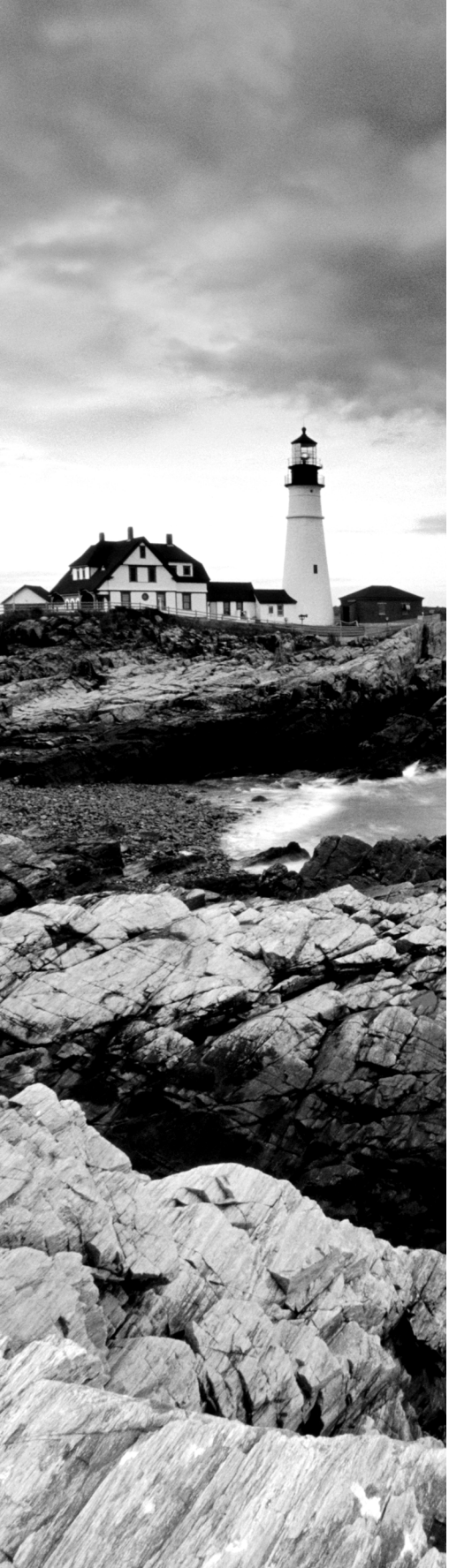


Glossary

Numbers

802.1X The IEEE standard that defines port-based security for network access control.

A

Acceptable use policy (AUP) A document that provides network and system users with clear direction on permissible uses of information resources.

Access badges Used for entry access via magnetic stripe and radio frequency ID (RFID) access systems and when including a picture, allow personnel to determine if the person is who they say they are, what areas or access they should have, and if they are an employee or a guest.

Access control list (ACL) Rule that either permits or denies actions.

Access control standards Describes the account life cycle from provisioning through active use and decommissioning.

Access restrictions Security measures that limit the ability of individuals or systems to access sensitive information or resources.

Account lockout Accounts are often locked out after failed login attempts. Since brute-force attacks often rely on multiple attempts to log in, this may be an indicator of compromise.

Acknowledgment Ensuring that employees and business partners state that they are aware of the compliance requirements.

ACL *See* access control list.

Active/active load balancer A kind of load balancer that distributes the load among multiple systems that are online and in use at the same time.

Active/passive load balancer A kind of load balancer that brings backup or secondary systems online when an active system is removed or fails to respond properly to a health check.

Active reconnaissance A technique that directly engages the target in intelligence gathering.

Ad hoc reports Reports that are produced as needed, typically in response to specific events or situations that require immediate attention or in-depth analysis.

Ad hoc risk assessment Conducted in response to a specific event or situation, often performed quickly, to address a particular concern or set of circumstances.

Adaptive identity Often called adaptive authentication, it leverages context-based authentication that considers data points like where the user is logging in from, what device they are logging in from, and whether the device meets security and configuration requirements.

Address resolution protocol (ARP) A protocol that provides translations between MAC addresses and IP addresses on a local network.

Admissibility Determination as to whether evidence is acceptable to be used in a court of law.

Advanced persistent threats (APTs) Cybersecurity adversary characterized by a sophisticated series of related attacks taking place over an extended period of time.

Adversarial artificial intelligence (AI) The use of artificial intelligence techniques by attackers for malicious purposes.

Adversary tactics, techniques, and procedures (TTPs) The study of the methods used by cybersecurity adversaries when engaging in attacks.

Agents Software that is deployed to endpoints allowing them to perform actions or to be controlled by a central server or service.

Agent-based scanning The use of software agents installed on target devices to assist with vulnerability scans.

Agile A software development model that is both iterative and incremental. The Agile methodology focuses on individuals and interactions over process and tools, working software over comprehensive documentation, customer collaboration over negotiation, and responding to change rather than following a plan.

Agility The speed to provision cloud resources and the ability to use them for short periods of time.

AH *See* authentication header.

Air gapped A design that physically separates network segments, preventing network connectivity between those segments.

ALE *See* annualized loss expectancy.

Algorithm A set of rules, usually mathematical, that dictates how enciphering and deciphering processes are to take place.

Allow listing The most effective form of input validation in which the developer describes the exact type of input that is expected from the user and then verifies that the input matches that specification before passing the input to other processes or servers.

Alteration The unauthorized modification of information and a violation of the principle of integrity.

Amplified denial-of-service attacks An amplified denial-of-service attack takes advantage of protocols that allow a small query to return large results like a DNS query. Spoofing a system's IP address as part of a query can result in a DNS server sending much more traffic to the spoofed IP address than was sent to the DNS server originally, amplifying a small amount of traffic into a large response.

Annualized loss expectancy (ALE) The possible yearly cost of all instances of a specific realized threat against a specific asset. The ALE is calculated using the formula ALE = single loss expectancy (SLE) * annualized rate of occurrence (ARO).

Annualized rate of occurrence (ARO) The expected frequency that a specific threat or risk will occur (in other words, become realized) within a single year. Also known as probability determination.

Anomalous behavior recognition Employees should be able to recognize when risky, unexpected, and/or unintentional behavior takes place.

Anomaly detection A method of detecting abnormal or malicious events by looking for abnormal occurrences or violations of specified rules. Anomaly detection is commonly used by intrusion detection systems (IDSs) and/or intrusion prevention systems (IPSs).

API *See* application programming interfaces.

API-based CASB solution Cloud Access Security Broker solutions do not interact directly with the user but rather interact directly with the cloud provider through the provider's API.

API inspection A technology that scrutinizes API requests for security issues.

Application programming interfaces (APIs) APIs allow application developers to interact directly with a web service through function calls.

ARO *See* annualized rate of occurrence.

Assessment Reviews of security controls that are typically requested by the security organization itself in an effort to engage in process improvement.

Asset criticality Determination of the importance of an asset to the business.

Asset inventory Systematic method of tracking hardware, software, and information assets owned by an organization.

Asset management A process that the organization will follow for accepting new assets (such as computers and mobile devices) into inventory, tracking those assets over their lifetime, and properly disposing of them at the end of their useful life.

Asset value (AV) A dollar value assigned to an asset based on actual cost and nonmonetary expenses.

Asymmetric key algorithms Cryptographic algorithms that use two different keys: one key to encrypt and another to decrypt. Also called public key cryptography.

ATT&CK A public knowledge base describing adversarial techniques and tactics maintained by MITRE.

Attack complexity metric (AC) A metric that describes the difficulty of exploiting a vulnerability.

Attack surface A system, application, or service that contains a vulnerability that might be exploited.

Attack vector metric (AV) A metric that describes how an attacker would exploit a vulnerability.

Attestation A primary outcome of an audit by an auditor. It is a formal statement that the auditors have reviewed the controls and found that they are both adequate to meet the control objectives and working properly.

Attribute-based access control (ABAC) An advanced implementation of a rule-based access control model that uses policies that include multiple attributes for rules.

Auditability Cloud computing contracts should include language guaranteeing the right of the customer to audit cloud service providers.

Audits Formal reviews of an organization's security program or specific compliance issues conducted on behalf of a third party.

AUP *See* acceptable use policy (AUP).

Authentication Verifies the claimed identity of system users and is a major function of cryptosystems.

Authentication header (AH) Uses hashing and a shared secret key to ensure integrity of data and validates senders by authenticating the IP packets that are sent. AH can ensure that the IP payload and headers are protected.

Authority A key principle that relies on the fact that most people will obey someone who appears to be in charge or knowledgeable, whether or not they actually are.

Authorized attackers Hackers who act with authorization and seek to discover security vulnerabilities with the intent of correcting them.

Availability Ensures that information and systems are ready to meet the needs of legitimate users at the time those users request them.

Availability metric (A) A metric that describes the type of disruption that might occur if an attacker successfully exploits a vulnerability.

B

Backdoors An opening left in a program application (usually by the developer) that allows additional access to data. Typically, a backdoor is created for debugging purposes and is not documented. Before the product ships, the backdoors are closed; when they aren't closed, security loopholes exist.

Background check A process designed to uncover any criminal activity or other past behavior that may indicate that a potential employee poses an undetected risk to the organization.

Badges Forms of physical identification and/or of electronic access control devices.

Bare-metal hypervisor *See* Type I hypervisor.

BC-DR *See* business continuity and disaster recovery.

Behavior-based detection An intrusion discovery mechanism used by intrusion detection systems (IDSs). Behavior-based detection finds out about the normal activities and events on your system by watching and learning. After it has accumulated enough data about normal activity, it can detect abnormal and possible malicious activities and events. Also known as statistical intrusion detection, anomaly detection, and heuristics-based detection.

BIA *See* business impact analysis.

Biometrics Widely available on modern devices, with fingerprints and facial recognition being the most broadly adopted and deployed.

Birthday attack This is an attack on cryptographic hashes, based on the birthday theorem.

Blackmail attacks Attacks seeking to extort money or other concessions from victims by threatening to release sensitive information or launching further attacks.

Blind content-based SQL injection The perpetrator sends input to the web application that tests whether the application is interpreting injected code before attempting to carry out an attack.

Blind SQL injection A kind of SQL injection attack that is conducted when the attacker doesn't have the ability to view the results directly.

Blind timing-based SQL injection In addition to using the content returned by an application to assess susceptibility to blind SQL injection attacks, penetration testers may use the amount of time required to process a query as a channel for retrieving information from a database.

Block ciphers Operate on "chunks" or blocks of a message and apply the encryption algorithm to an entire message block at the same time.

Block storage Allocates large volumes of storage for use by virtual server instance(s).

Blockchain A distributed and immutable open public ledger. It can store records in a way that distributes those records among many different systems located around the world and does so in a manner that prevents anyone from tampering with those records.

Bluejacking Hijacking a Bluetooth connection to eavesdrop or extract information from devices.

Bluesnarfing An attack that allows hackers to connect with your Bluetooth devices without your knowledge and extract information from them. Bluesnarfing can offer attackers access to your contact lists, your data, and even your conversations.

Blue team Defenders who must secure systems and networks from attack.

Bluetooth A wireless standard commonly used to pair accessories to mobile phones or computers.

Board of directors Has ultimate authority over the organization as the owners' representatives.

Bollards Posts or other obstacles that prevent vehicles from moving through an area.

Bot An automated software program (network robot) that collects information on the web. In its malicious form, a bot is a compromised computer being controlled remotely.

BPA *See* business partners agreement.

BPDU *See* bridge protocol data unit.

Brand impersonation Another type of phishing attack that uses emails that are intended to appear to be from a legitimate brand, relying on name recognition and even using email templates used by the brand itself.

Bridge Protocol Data Unit (BPDU) guard A switch security feature that blocks Spanning Tree Protocol (STP) attacks by preventing updates from unauthorized ports.

Bring your own device (BYOD) The user brings their own personally owned device.

Broadcast storm A flood of unwanted broadcast network traffic.

Brute-force attacks A type of attack that systematically tries all possibilities for a password until achieving a successful result.

Buffer overflow A type of denial-of-service (DoS) attack that occurs when more data is put into a buffer than it can hold, thereby overflowing it (as the name implies).

Bursting Leveraging public cloud capacity when demand exceeds the capacity of private cloud infrastructure.

Business constraints In terms of vulnerability, they may limit the organization from conducting resource-intensive vulnerability scans during periods of high business activity to avoid disruption of critical processes.

Business continuity and disaster recovery Outline the procedures and strategies to ensure that essential business functions continue to operate during and after a disaster, and that data and assets are recovered and protected.

Business email compromise (BEC) Relies on using apparently legitimate email addresses to conduct scams and other attacks.

Business impact analysis (BIA) A formal process designed to identify the mission-essential functions within an organization and facilitate the identification of the critical systems that support those functions.

Business partners agreement (BPA) Exists when two organizations agree to do business with each other in a partnership.

BYOD *See* bring your own device.

C

CA *See* certificate authority.

CAM table Maps MAC addresses to IP addresses, allowing a switch to send traffic to the correct port.

Capture the flag (CTF) An exercise that pits technologists against one another in an attempt to attack a system and achieve a specific goal, such as stealing a sensitive file.

Card cloning attack A kind of attack that focuses on capturing information from cards like RFID and magstripe cards often used for entry access.

Carrier unlocking Allows mobile phones to be used with other cellular providers.

CASB *See* cloud access security broker.

CCMP (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol) Encryption technology used in the WPA2 protocol. It implements AES (Advanced Encryption Standard) with a 128-bit key as a stream cipher.

CCTV *See* closed-circuit television.

Cellular A kind of wireless connection that provides connectivity for mobile devices like cell phones by dividing geographic areas into "cells," with tower coverage allowing wireless communications between devices and towers or cell sites.

Center for Internet Security (CIS) An industry organization that publishes hundreds of benchmarks for commonly used platforms.

Centralized Centralized approach to computing places a significant portion of an organization's infrastructure within a single environment.

Centralized proxy Traffic is routed through the device.

Certificate Certificates can be stored on a system or paired with a storage device or security token and are often used to identify systems or devices as well as individuals.

Certificate authorities (CAs) CAs are the glue that binds the public key infrastructure together. These neutral organizations offer notarization services for digital certificates.

Certificate chaining The use of a series of intermediate CAs in the certificate authority trust model.

Certificate revocation list (CRL) Used to ensure that the certificate was not revoked.

Certificate signing request (CSR) Provides your public key to the certificate authority to create an X.509 digital certificate containing your identifying information and a copy of your public key. The CA then digitally signs the certificate using the CA's private key and provides you with a copy of your signed digital certificate.

Certificate stapling This is an extension to the Online Certificate Status Protocol (OCSP) that relieves some of the burden placed upon certificate authorities by the original protocol. The web server contacts the OCSP server itself and receives a signed and timestamped response from the OCSP server, which it then attaches to the digital certificate.

Certification The comprehensive evaluation, made in support of the accreditation process, of the technical and nontechnical security features of an IT system and other safeguards to establish the extent to which a particular design and implementation meets a set of specified security requirements.

Chain of custody The process by which investigators document the handling of evidence from collection through use in court.

Challenge handshake authentication protocol (CHAP) A protocol that challenges a user or system to verify its identity without sending a secret key over the network.

Change control *See* change management.

Change management Process that defines how the organization will review, approve, and implement proposed changes to information systems in a manner that manages both cybersecurity and operational risk.

Choose your own device (CYOD) The organization owns the device but allows the user to select and maintain it.

Chosen plain text The attacker obtains the ciphertexts corresponding to a set of plain texts of their own choosing.

CIA triad The three essential security principles of confidentiality, integrity, and availability.

Cipher A system that hides the true meaning of a message. Ciphers use a variety of techniques to alter and/or rearrange the characters or words of a message to achieve confidentiality.

Clean desk policy A policy used to instruct workers how and why to clean off their desks at the end of each work period. In relation to security, such a policy has a primary goal of reducing disclosure of sensitive information.

Closed-circuit television (CCTV) Displays what the camera is seeing on a screen. Some CCTV systems include recording capabilities as well.

Closed-source intelligence Intelligence information, typically from a commercial vendor that is provided only to specific groups.

Cloud access security broker (CASB) A security policy enforcement solution that consistently enforces security policies across cloud providers.

Cloud auditors Independent organizations that provide third-party assessments of cloud services and operations.

Cloud bursting Moving the execution of an application to the cloud on an as-needed basis.

Cloud carriers The intermediaries that provide the connectivity that allows the delivery of cloud services from providers to consumers.

Cloud computing A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources.

Cloud consumers The organizations and individuals who purchase cloud services from cloud service providers.

Cloud partners The organizations that offer ancillary products or services that support or integrate with the offerings of a cloud service provider.

Cloud service providers The firms that offer cloud computing services to their customers.

Clustering Describes groups of computers connected together to perform the same task.

COBIT *See* control objectives for information and related technologies.

COBO *See* company-owned business only.

Code injection attacks Attacks seeking to insert attacker-written code into the legitimate code created by a web application developer.

Code of conduct/ethics A document that describes expected behavior of employees and affiliates and covers situations not specifically addressed in policy.

Code repositories Centralized locations for the storage and management of application source code.

Code review A form of vulnerability assessment where flaws in code or errors in logic are detected by combing through source code.

Code signing A way for developers to confirm the authenticity of their code to end users.

Cold aisles Server room aisles that blow cold air from the floor.

Cold sites Standby facilities large enough to handle the processing load of an organization and with appropriate electrical and environmental support systems.

Collisions Cases where a hash function produces the same value for two different methods.

Column-level encryption (CLE) Allows for specific columns within tables to be encrypted.

Common configuration enumeration (CCE) Provides a standard nomenclature for discussing system configuration issues.

Common name (CN) Clearly describes the certificate owner.

Common platform enumeration (CPE) Provides a standard nomenclature for describing product names and versions.

Common vulnerabilities and exposures (CVE) Provides a standard nomenclature for describing security-related software flaws.

Common vulnerability scoring system (CVSS) Security Content Automation Protocol (SCAP) component that provides a standardized scoring system for describing the characteristics and severity of security vulnerabilities.

Community cloud Cloud delivery model in which the infrastructure is shared by organizations with something in common.

Company-owned business only (COBO) Most frequently used to describe company-owned devices used only for business work.

Compensating controls Gap controls that fill in the coverage between other types of vulnerability mitigation techniques (where there are holes in coverage, we compensate for them).

Compliance reporting Ensures that organizations meet the regulatory requirements and maintain transparency within the organization and with external stakeholders.

Compliance risk The risk that a security breach causes an organization to run afoul of legal or regulatory requirements.

Computer-based training (CBT) Method of delivering training content to users by digital means.

Concurrent session usage An indicator of compromise that occurs when a session is used from more than one location or device at a time.

Confidential Information that requires some protection.

Confidentiality Ensures that unauthorized individuals are not able to gain access to sensitive information.

Confidentiality metric (C) A metric that describes the type of information disclosure that might occur if an attacker successfully exploits the vulnerability.

Configuration management The process of logging, auditing, and monitoring activities related to security controls and security mechanisms over time. This data is then used to identify agents of change, such as objects, subjects, programs, communication pathways, or even the network itself.

Conflicts of interest Arise when a vendor has a competing interest that could influence their behavior in a way that is not aligned with the best interests of the organization.

Consensus A key principle in social engineering that uses the fact that people tend to want to do what others are doing to persuade them to take an action.

Conservative risk appetite Organization tends to avoid high risk and focus on maintaining stability and protecting existing assets.

Container Standardized software package that includes all code and libraries to facilitate execution on any hardware and operating system supporting the same containerization platform.

Containerization This is an increasingly common solution to handling separation of work and personal-use contexts on devices.

Containment Prevention of the spread of malicious code or other attacks.

Content filters Devices or software that allow or block traffic based on content rules.

Context-aware authentication Goes beyond PINs, passwords, and biometrics to better reflect user behavior. Context may include things like location, hours of use, and a wide range of other behavioral elements that can determine whether a user should be able to log in.

Continuity of operations Ensuring that operations will continue even if issues ranging from single system failures to wide-scale natural disasters occur.

Continuous delivery (CD) *See* continuous deployment.

Continuous deployment (CD) Sometimes called continuous delivery; it rolls out tested changes into production automatically as soon as they have been tested.

Continuous integration (CI) A development practice that checks code into a shared repository on a consistent, ongoing basis.

Continuous monitoring A monitoring practice that uses automation to facilitate 24/7 monitoring of systems and networks.

Continuous risk assessment Involves ongoing monitoring and analysis of risks.

Continuous validation Using continuous integration and continuous deployment methods requires building continuous validation and automated security testing into the pipeline testing process.

Control objectives The requirements of the level of protection required to preserve the confidentiality, integrity, and availability of an organization's information and systems.

Control objectives for information and related technologies (COBIT) Describes the common requirements that organizations should have in place surrounding their information systems.

Cookie A plain-text file stored on your machine that contains information about you (and your preferences) for use by a database server. Although cookies are frequently used for various legitimate purposes, they can also be used by malicious websites to track user activities.

COPE *See* corporate-owned, personally enabled (COPE).

Corporate-owned Provides the greatest control but least flexibility for devices.

Corporate-owned, personally enabled (COPE) Corporate-provided devices that allow reasonable personal use while meeting enterprise security and control needs.

Corrective controls A type of access control that modifies the environment to return systems to normal after an unwanted or unauthorized activity has occurred.

Credential harvesting The process of gathering credentials like usernames and passwords.

Credential management policy A document that describes the account life cycle from provisioning through active use and decommissioning.

Credential replay Attacks are a form of network attack that requires the attacker to be able to capture valid network data and to re-send it or to delay it so that the attacker's own use of the data is successful.

Credentialed scanning Access operating systems, databases, and applications, among other sources.

Cross-site request forgery (XSRF/CSRF) An attack that is similar in nature to that of XSS. However, with XSRF, the attack is focused on the visiting user's web browser more so than the website being visited. The main purpose of XSRF is to trick the user or the user's browser into performing actions they did not intend or would not have authorized.

Cross-site scripting (XSS) Running a script routine on a user's machine from a website without their permission.

Crossover error rate (CER) The point at which the false rejection rate (FRR) and the false acceptance rate (FAR) are equal. Sometimes called the equal error rate (ERR).

Cryptanalysis The study of methods to defeat codes and ciphers.

Cryptocurrency The first major application of the blockchain. Blockchain allows the existence of a currency that has no central regulator.

Cryptography Algorithms applied to data that are designed to ensure confidentiality, integrity, authentication, and/or nonrepudiation. The art of creating and implementing secret codes and ciphers.

Cryptology Together, cryptography and cryptanalysis are commonly referred to as cryptology.

Cryptosystems Specific implementations of a code or cipher in hardware and software.

Cryptovariables Cryptographic keys.

CSF *See* Cybersecurity framework (CSF).

CSR *See* certificate signing request.

CSRF *See* cross-site request forgery.

curl A tool that is found on Linux systems and that is used to transfer data via URLs.

CVSS base score A single number representing the overall risk posed by the vulnerability.

CVSS vector A vector that uses a single-line format to convey the ratings of a vulnerability on all six of the metrics.

Cyber kill chain A seven-step process of mapping attacks from their beginning to end.

Cybersecurity framework (CSF) NIST cybersecurity framework provides organizations with a sound approach to developing and evaluating the state of their cybersecurity programs.

Cybersecurity insurance Insurance policy designed to protect an organization against cybersecurity risks.

CYOD *See* choose your own device.

D

DAD Triad The three key threats to cybersecurity efforts: disclosure, alteration, and denial.

Dark web An anonymous network created through encryption technology and often used for illicit activity.

Dashboard reporting Utilizes visual aids like graphs and charts to summarize risk data, usually in real time.

Data at rest Stored data that resides on hard drives, on tapes, in the cloud, or on other storage media.

Data breach notification law Laws requiring the notification of data subjects after a known or suspected breach.

Data classification policy A document that describes the classification structure used by the organization and the process used to properly assign classifications to data.

Data controller In the context of a data processor, as defined by the European Union data protection laws, the person or entity that controls processing of the data.

Data custodian The user who is assigned the task of implementing the prescribed protection defined by the security policy and upper management. The data custodian performs any and all activities necessary to provide adequate protection for data and to fulfill the requirements and responsibilities delegated to them from upper management.

Data exfiltration attack An attack in which access to sensitive information is gained and then removed from an organization.

Data exposure The concept that sensitive personal information in databases exposes an organization to risk in the event that information is stolen by an attacker.

Data governance policy A document that clearly states the ownership of information created or used by the organization.

Data in transit Data that is in transit over a network.

Data in use Data that is actively in use by a computer system.

Data inventory The first step in managing sensitive data is developing a data inventory of the types of information maintained by the organization and the places where that data is stored, processed, and transmitted.

Data loss The exposure of sensitive information to unauthorized individuals.

Data loss prevention (DLP) Any systems that identify, monitor, and protect data to prevent it from unauthorized use, modification, destruction, egress, or exfiltration from a location.

Data masking A tool that redacts sensitive information by replacing some of or all sensitive fields with blank characters.

Data minimization The techniques seeking to reduce risk by reducing the amount of sensitive information maintained on a regular basis.

Data obfuscation The process that transforms data into a format where the original information can't be retrieved.

Data owner The person responsible for classifying information for placement and protection within the security solution.

Data ownership The organization designates specific senior executives as the data owners for different data types.

Data processor An individual or entity (in legal terms, a natural or legal person) who processes personal data solely on behalf of the data controller.

Data protection officer (DPO) A specific individual who bears overall responsibility for carrying out the organization's data privacy efforts.

Data retention policy A document that outlines what information the organization will maintain, and the length of time different categories of work product will be retained before destruction.

Data sovereignty A principle that states that data is subject to the legal restrictions of any jurisdiction where it is collected, stored, or processed.

Data steward An individual who is responsible for carrying out an organization's data security policies and overseeing data usage based on those policies.

Data subject Individual whose personal data is being processed.

Database encryption Targets data at the database level. It is a method used to protect sensitive information stored in a database from access by unauthorized individuals.

Database normalization The process of removing duplication in a relational database.

Dead code Code that is in use in an organization, but nobody is responsible for the maintenance of that code, and in fact, nobody may even know where the original source files reside.

Debug modes The feature that gives developers crucial error information needed to troubleshoot applications in the development process.

Decentralized An approach that reduces single points of failure by spreading technology components across multiple providers.

DDoS One of the most common forms of the distributed denial-of-service attacks is a network-based DDoS. Malicious actors commonly use large-scale botnets to conduct network DDoS attacks, and commercial services exist that conduct DDoS attacks and DDoS-like behavior for stress- and load-testing purposes.

Defensive penetration testing Focuses on evaluating an organization's ability to defend against cyberattacks. Unlike offensive penetration testing, which aims to exploit vulnerabilities, defensive penetration testing involves assessing the effectiveness of security policies, procedures, and technologies in detecting and mitigating threats.

Deidentification process Removes the ability to link data back to an individual, reducing its sensitivity.

Demilitarized zone (DMZ) A network zone that resides between an internal network and the Internet used to host systems that require public access.

Denial The unintended disruption of an authorized user's legitimate access to information.

Deny listing Developers use this method to control user input by describing potentially malicious input that must be blocked during input validation.

Deprovisioned When an account is terminated.

Detective controls A type of access control that is deployed to discover or detect unwanted or unauthorized activity.

Deterrent controls A type of access control that is deployed to discourage violation of security policies.

Development environment Typically used for developers or other "builders" to do their work.

Device driver Software interface between hardware devices and the operating system.

DevOps The DevOps approach seeks to resolve issues of software development, quality assurance, and technology operations by bringing the three functions together in a single operational model. The word *DevOps* is a combination of development and operations, symbolizing that these functions must merge and cooperate to meet business requirements.

DevSecOps DevOps model that includes security as a core component.

DHCP *See* dynamic host configuration protocol.

Diamond model of intrusion analysis An intrusion analysis model that focuses on adversaries, infrastructure, victims, and capabilities using a diamond shape to guide analysis through the connected vertices.

Dictionary attack The act of attempting to crack passwords by testing them against a list of dictionary words.

Differential backup A type of backup that stores all files that have been modified since the time of the most recent full backup.

`dig` A tool that performs a lookup of an IP address to return a domain name, or a domain name to return an IP address, and looks up specific DNS information like MX (mail server), A, and other DNS records.

Digital certificates An electronic document used to securely share a private key with third parties based on the assurance provided by a certificate authority (CA).

Digital rights management (DRM) A type of protection software that uses encryption to enforce copyright restrictions on digital media. Over the past decade, publishers attempted to deploy DRM schemes across a variety of media types, including music, movies, and books.

Digital signatures Message integrity is enforced using encrypted message digests, known as digital signatures, created upon transmission of a message.

Directive controls Inform employees and others what they should do to achieve security objectives.

Directory service A centralized database of resources available to the network, much like a telephone directory for network services and assets. Users, clients, and processes consult the directory service to learn where a desired system or resource resides.

Directory traversal An attack that allows an attacker to jump out of the web root directory structure and into any other part of the filesystem hosted by the web server's host operating system.

Disassociation An attack in which the intruder sends a frame to a wireless access point with a spoofed address to make it look as if it came from the victim and then disconnects them from the network.

Disaster recovery plan (DRP) Term that describes the actions an organization takes to resume normal operations after a disaster interrupts normal activity.

Disclosure The occurrence of a violation of confidentiality when resources are made accessible to unauthorized entities.

Discretionary access control A mechanism used to control access to objects. The owner or creator of an object controls and defines the access other subjects have to it.

Disinformation Incorrect, inaccurate, or outright false information that is intentionally provided to serve an individual or organization's goals.

Disposition A software development phase that occurs when a product or system reaches the end of its life.

Disruption/chaos attacks Attacks that are motivated by a desire to cause chaos and disrupt normal operations.

DKIM *See* DomainKeys identified mail.

DLL injection attack A variant of SQL injection, where commands may attempt to load dynamic link libraries (DLLs) containing malicious code.

DLP *See* data loss prevention (DLP).

DMARC *See* domain-based message authentication reporting and conformance (DMARC).

DNS *See* domain name system.

DNS filtering Used by many organizations to block malicious domains.

DNS poisoning Can be accomplished in multiple ways. One form is another form of the on-path attack where an attacker provides a DNS response while pretending to be an authoritative DNS server. Vulnerabilities in DNS protocols or implementations can also

permit DNS poisoning, but they are rarer. DNS poisoning can also involve poisoning the DNS cache on systems. Once a malicious DNS entry is in a system's cache, it will continue to use that information until the cache is purged or updated. This means that DNS poisoning can have a longer-term impact, even if it is discovered and blocked by an IPS or other security device.

DNS sinkhole A DNS server that is configured to provide incorrect answers to specific DNS queries.

dnsenum A command-line tool that is used to find DNS servers and entries for a domain. It can be directed to query a specific DNS server or default to the DNS server the system on which it is running relies on.

DNSSEC *See* domain name system security extensions.

Documentation Identifies the current configuration of systems. It identifies who is responsible for the system and its purpose and lists all changes applied to the baseline.

Domain-based message authentication reporting and conformance (DMARC) A protocol that uses SPF and DKIM to determine if an email message is authentic.

Domain hijacking Changes the registration of a domain. The domain's settings and configuration can be changed by an attacker, allowing them to intercept traffic, send and receive email, or otherwise take action while appearing to be the legitimate domain holder.

Domain reputation Services and tools provide information about whether a domain is a trusted email sender or sends a lot of spam email. In addition, individual organizations may assign domain reputation scores for email senders using their own email security and antispam tools.

Domain name system (DNS) The network service used in TCP/IP networks that translates hostnames to IP addresses. *See also* Transmission Control Protocol/Internet Protocol (TCP/IP).

Domain name system security extensions (DNSSEC) Provide authentication of DNS data, allowing DNS queries to be validated even if they are not encrypted.

Domain validation (DV) certificates The CA simply verifies that the certificate subject has control of the domain name.

DomainKeys identified mail (DKIM) Allows organizations to add content to messages to identify them as being from their domain.

Downgrade attack Sometimes used against secure communications such as TLS in an attempt to get the user or system to inadvertently shift to less secure cryptographic modes.

DPO *See* data protection officer.

Due care Refers to the ongoing efforts to ensure that the implemented policies and controls are effective and continuously maintained.

Due diligence Involves thoroughly vetting potential vendors to ensure that they meet the organization's standards and requirements.

Dumpster diving Looking through trash for clues—often in the form of paper scraps—to find users' passwords and other pertinent information.

Dynamic code analysis Analyzing the execution of code while providing it with input to test the software.

Dynamic Host Configuration Protocol (DHCP) A protocol used to assign TCP/IP configuration settings to systems upon bootup. DHCP uses UDP port 67 for server point-to-point response and port 68 for client request broadcast. DHCP supports centralized control and management of network addressing.

Dynamic packet-filtering firewall A firewall that enables real-time modification of the filtering rules based on traffic content. Dynamic packet-filtering firewalls are known as fourth-generation firewalls.

Dynamic testing Evaluates the security of software in a runtime environment and is often the only option for organizations deploying applications written by someone else.

E

EAP-FAST (Extensible Authentication Protocol-Flexible Authentication via Secure Tunneling) A Cisco-developed protocol that improved on vulnerabilities in the Lightweight Extensible Authentication Protocol (LEAP).

EAP-TLS (Extensible Authentication Protocol-Transport Layer Security) Implements certificate-based authentication as well as mutual authentication of the device and network.

EAP-TTLS (Extensible Authentication Protocol-Tunneled Transport Layer Security) Extends EAP-TLS, and unlike EAP-TLS, it does not require that client devices have a certificate to create a secure session.

Edge computing An approach that seeks to address this issue by placing some processing power on the remote sensors, allowing them to preprocess data before shipping it back to the cloud.

E-discovery *See* electronic discovery.

EDR *See* endpoint detection and response.

Elasticity A principle of system resilience, which says that systems should be able to automatically provision resources to scale when necessary and then automatically deprovision those resources to reduce capacity (and cost) when it is no longer needed.

Electronic discovery (E-discovery) In legal proceedings, each side has a duty to preserve evidence related to the case and, through the discovery process, share information with their adversary in the proceedings. This discovery process applies to both paper records and electronic records, and the electronic discovery (or E-discovery) process facilitates the processing of electronic information for disclosure.

Eliciting information A technique used to gather information without targets realizing they are providing it.

Elliptic curve cryptography (ECC) Theory to develop secure cryptographic systems.

Email metadata A type of metadata that includes headers and other information found in an email.

Email security gateway Devices designed to filter both inbound and outbound email while providing a variety of security services like phishing protection, email encryption, attachment sandboxing to counter malware, ransomware protection functions, URL analysis and threat feed integration, and support for DKIM, SPF, and DMARC checking.

Encapsulating security payload (ESP) Operates in either transport mode or tunnel mode. In tunnel mode, it provides integrity and authentication for the entire packet; in transport mode, it only protects the payload of the packet. If ESP is used with an authentication header, this can cause issues for networks that need to change IP or port information.

Encryption The process of converting plain text that is readable by anyone into encrypted text or ciphertext. This ciphertext will be unreadable to anyone able to intercept it. The general rule is that all encryption can be broken if an attacker has enough time and resources. That said, the idea is to use encryption that is stronger than the data is valuable.

Encryption standards Specify the requirements for encrypting data both in transit and at rest.

End of life (EOL) A term used by original equipment manufacturers to note that the device or system is no longer being produced and will no longer be marketed or sold after a given date.

End-of-service life (EOSL) A term used by original equipment manufacturers meaning that the OEM no longer sells, updates, or provides service for devices or systems.

Endpoint Devices are often called endpoints, meaning they're an endpoint of a network, whether that is a wired or a wireless network.

Endpoint detection and response (EDR) EDR tools combine monitoring capabilities on endpoint devices and systems using a client or software agent with network monitoring and log analysis capabilities to collect, correlate, and analyze events.

Enterprise risk management (ERM) A formal approach to risk analysis that begins with identifying risks, continues with determining the severity of each risk, and then results in adopting one or more *risk management* strategies to address each risk.

Entropy When your key is truly random, it is said to have sufficient entropy.

Environmental attacks Include attacks like targeting an organization's heating and cooling systems, maliciously activating a sprinkler system, and similar actions.

EOL *See* end of life.

EOSL *See* end-of-service life.

Ephemeral key A key generated at time of need for use in a short or temporary timeframe. An ephemeral key might be used only once or could be used for a communication session before being discarded.

Error handling Developers must anticipate unexpected situations and write error handling code that steps in and handles these situations in a secure fashion.

ESP *See* encapsulating security payload.

Espionage Attacks are motivated by organizations seeking to steal secret information from other organizations. This may come in the form of nation-states attacking each other or corporate espionage.

Ethical attacks Attacks are motivated by a desire to expose vulnerabilities and improve security.

Evidence production procedures Procedures that describe how the organization will respond to subpoenas, court orders, and other legitimate requests to produce digital evidence.

Expansionary risk appetites Organizations willing to take on higher levels of risk in the pursuit of potentially higher rewards.

Exploitation frameworks A tool that simplifies the use of vulnerabilities by providing a modular approach to configuring and deploying vulnerability exploits.

Exposure factor (EF) The percentage of loss that an organization would experience if a specific asset were violated by a realized risk. Also known as loss potential.

Extended detection and response (XDR) XDR is similar to EDR but has a broader perspective considering not only endpoints but the full breadth of an organization's technology stack, including cloud services, security services and platforms, and similar components.

Extended validation (EV) certificates Provide a higher level of assurance and the CA takes steps to verify that the certificate owner is a legitimate business before issuing the certificate.

Extensible Authentication Protocol (EAP) An authentication expansion system where new or custom mechanisms that perform authentication can be added to existing systems.

Extensible Configuration Checklist Description Format (XCCDF) A language for specifying checklists and reporting checklist results.

External audits Performed by an outside auditing firm who serves as an independent third party.

External monitoring Involves third-party audits and assessments, which provide an unbiased view of the organization's compliance status.

External risk Risks that originate from a source outside the organization. This is an extremely broad category of risk, including cybersecurity adversaries and malicious code and natural disasters, among many other types of risk.

External threat actors Threat actors who exist outside our organizations: competitors, criminals, and the curious.

Extranet Web (or similar) services set up in a private network to be accessed internally and by select external entities, such as vendors and suppliers.

F

FaaS *See* function as a service.

Facial recognition A technique that matches specific features to an original image in a database.

Fagan inspection A formal code review process that uses formal phases and specifies entry and exit criteria for each phase.

Fail-closed If a fail-closed device fails, the organization may not be able to conduct business.

Fail-open If a fail-open device fails, the organization may not have the security controls.

Failover exercises Test full failover to an alternate site or system. They have the greatest potential for disruption but also provide the greatest chance to fully test in a real-world scenario.

Fake telemetry data Part of deception efforts that provides additional targets for attackers.

False acceptance rate (FAR) The rate at which a biometric solution allows in individuals it should have rejected.

False negative report An inaccurate report.

False positive error A flagged event that isn't really an event and has been falsely triggered.

False rejection rate (FRR) The rate at which a biometric solution rejects individuals it should have allowed.

Familiarity A key principle in social engineering that relies on your liking the individual or even the organization the individual is claiming to represent.

Family Educational Rights and Privacy Act (FERPA) Privacy law governing the student educational records maintained by educational institutions in the United States who receive certain types of funding from the U.S. Department of Education.

Faraday cage An enclosure that absorbs or blocks electromagnetic (EM) signals from entering or leaving the contained space.

FDE *See* Full-disk encryption.

Fence A perimeter-defining device. Fences are used to clearly differentiate between areas that are under a specific level of security protection and those that are not. Fencing can include a wide range of components, materials, and construction methods.

FERPA *See* Family Educational Rights and Privacy Act.

File and code repositories IoCs may be found in file and code repositories that offer threat intelligence information.

File inclusion attacks An attack that executes the code contained within a file, allowing the attacker to fool the web server into executing arbitrary code.

File integrity monitor (FIM) Creates a signature or fingerprint for a file, and then monitors the file and filesystem for changes to monitored files. FIM focuses on unexpected and unintended changes.

File-level encryption Focuses on individual files. This method allows users to encrypt specific files rather than entire drives or partitions.

File metadata A type of metadata that can be a powerful tool when reviewing when a file was created, how it was created, if and when it was modified, who modified it, the GPS location of the device that created it, and many other details.

Filesystem controls Determine which accounts, users, groups, or services can perform actions like reading, writing, and executing files.

FIM *See* file integrity monitor.

Financial gain attacks Attacks that are motivated by the desire to make money through theft or fraud.

Financial information Information that includes any personal financial records maintained by the organization.

Financial risk The risk of monetary damage to the organization as the result of a data breach.

Fingerprints The patterns of ridges on the fingers of humans. Often used as a biometric authentication factor.

Fire suppression The act of extinguishing (or attempting to extinguish) a fire.

Firewall Filters traffic.

Firmware The embedded software that allows devices to function.

Fog computing A concept that uses Internet of Things (IoT) gateway devices that are located in close physical proximity to the sensors.

Footprinting The process of systematically identifying a network and its security posture.

Forward proxy A type of proxy that is placed between clients and servers, and that accepts requests from clients and sends them forward to servers.

Frequency analysis A cryptographic analysis or attack that looks for repetition of letters in an encrypted message and compares that with the statistics of letter usage for a specific language, such as the frequency of the letters E, T, A, O, N, R, I, S, and H in the English language.

Full backup A complete copy of data contained on the protected device on the backup media.

Full-disk encryption A type of disk encryption that encrypts the disk and requires that the bootloader or a hardware device provide a decryption key and software or hardware to decrypt the drive for use.

Full-tunnel VPN A virtual private network (VPN) that sends all network traffic through the VPN tunnel, keeping it secure as it goes to the remote trusted network.

Function as a service (FaaS) An example of platform-as-a-service (PaaS) computing that allows customers to upload their own code functions to the provider; the provider will then execute those functions on a scheduled basis, in response to events, and/or on demand.

Fuzz testing *See* fuzzing.

Fuzzing A method of testing that intentionally enters invalid input to see if the application can handle it.

G

Gait analysis A technique that measures how a person walks to identify them.

Gamification Designed to make training more enjoyable and help users retain the message of the campaign.

Gap analysis During a gap analysis, the cybersecurity professional reviews the control objectives for a particular organization, system, or service and then examines the controls designed to achieve those objectives.

GDPR *See* General Data Protection Regulation.

General Data Protection Regulation (GDPR) The European Union law that provides a single, harmonized law covering data security and privacy.

Generic accounts Shared accounts that are often prohibited by security policies.

Geographic dispersion of systems Ensures that a single disaster, attack, or failure cannot disable or destroy systems.

Geographic restrictions Limit access to resources based on the physical location of the user or system.

Geolocation GPS technology is a major part of geolocation capabilities used to determine where a device is. Geolocation is used for location aware authentication, geofencing, and other functions.

GLBA *See* Gramm–Leach–Bliley Act.

Global positioning system (GPS) A technique that uses a constellation of satellites that send out GPS signals that are received with a compatible GPS receiver. Receiving a fix requires signals from at least three satellites.

Governance Governance programs are the sets of procedures and controls put in place to allow an organization to effectively direct its work.

Gramm–Leach–Bliley Act (GLBA) U.S. law passed in 1999 that eased the strict governmental barriers between financial institutions and created new security and privacy requirements.

Guest account Account provided to a temporary user and that typically has very limited privileges, but it is also likely to have far less information about the user who uses it, if any.

Guideline A document that offers recommendations on how standards and baselines are implemented. Guidelines outline methodologies, including suggested actions, and are not compulsory.

H

Hacker mindset An approach for finding flaws by thinking like the adversary who might attack the system in the real world.

Hacktivists People who use hacking techniques to accomplish an activist goal.

Hardware security module (HSM) A cryptoprocessor used to manage/store digital encryption keys, accelerate cryptographic operations, support faster digital signatures, and improve authentication.

Hash functions Take a potentially long message and generate a unique output value derived from the content of the message.

Hashing Creation of a message digest from a message using a one-way cryptographic hash function.

Health Insurance Portability and Accountability Act (HIPAA) A U.S. health-care law that creates security and privacy requirements for handling protected health information.

HIDS See host-based intrusion detection system.

High availability (HA) The ability of a service, system, network, or other element of infrastructure to be consistently available without downtime.

HIPAA *See* Health Insurance Portability and Accountability Act.

HIPS *See* host-based intrusion prevention system.

HMAC-based one-time password (HOTP) Devices or applications that generate passwords that are not based on fixed time intervals but that instead generate passwords based on a nonrepeating one-way function, such as a hash or HMAC (Hash-based Message Authentication Code) operation. Also known as asynchronous dynamic password tokens.

Hoax Typically, an email message warning of something that isn't true, such as an outbreak of a new virus. A hoax can send users into a panic and cause more harm than the virus.

Homomorphic encryption Technology that allows encrypting data in a way that preserves the ability to perform computation on that data.

Honeyfile An intentionally attractive file that contains unique, detectable data that is left in an area that an attacker is likely to visit if they succeed in their attacks.

Honeynet Two or more networked honeypots used in tandem to monitor or re-create larger, more diverse network arrangements.

Honeypot A bogus system set up to attract and slow down a hacker.

Honeytoken Data that is intended to be attractive to attackers but that is used specifically to allow security professionals to track data.

Horizontal scaling Involves adding more servers to a pool of clustered servers.

Host-based firewalls Protect endpoints from network attacks by stopping unwanted traffic.

Host-based intrusion detection system (HIDS) Analyzes traffic before services or applications on the host process it, but it cannot take action to block traffic. Instead, it reports and alerts on issues.

Host-based intrusion prevention system (HIPS) Analyzes traffic before services or applications on the host process it. It can take action on that traffic, including filtering out malicious traffic or blocking specific elements of the data that is received.

Hot aisles A server room aisle that removes hot air from the facility.

Hot site A configuration in which a backup facility is maintained in constant working order, with a full complement of servers, workstations, and communications links ready to assume primary operations responsibilities.

HOTP *See* HMAC-based one-time password.

`hping` A tool that is used to assemble and analyze TCP/IP packets.

HSM *See* hardware security module.

HTML injection An attack in which attackers insert their own HTML code into a web page.

Hybrid cloud Any cloud delivery model that combines two or more of the other delivery model types.

Hypertext Transfer Protocol (HTTP) The protocol used for communication between a web server and a web browser.

Hypervisor Software that manages the access of virtual machines to underlying hardware resources.

I

IaaS *See* Infrastructure as a Service.

ICS *See* Industrial control system.

Identity Identities are the sets of claims made about a subject.

Identity fraud The use of someone else's identity.

Identity proofing The process of ensuring that the person who the account is being created for is the person who is claiming the account.

Identity provider (IdP) A provider of identity in a federation that makes assertions about identities to relying parties and releases information to relying parties about identity holders.

Identity theft When a security breach strikes an organization, the effects of that breach often extend beyond the walls of the breached organization, affecting customers, employees,

and other individual stakeholders. The most common impact on these groups is the risk of identity theft posed by exposure of personally identifiable information (PII) to unscrupulous individuals.

IdP *See* Identity provider.

IDS *See* Intrusion detection system.

IKE (Internet Key Exchange) A protocol used to set up a secure association as part of the IPSec protocol suite.

Image A complete copy of a system or server.

Impact A measurement of the amount of damage or loss that could be or will be caused if a potential threat is realized.

Impersonation Pretending to be another to gain information.

Implicit trust zone Allows use and movement once a subject is authenticated by a Zero Trust policy engine.

Impossible travel An indicator of compromise that occurs when logins or other actions are done in locations that are impossible to travel between in the time between when they occur.

In the clear Unencrypted.

Incremental backup A backup that stores only those files that have been modified since the time of the most recent full or incremental backup. This term is also used to mean the process of creating such a backup.

Independent directors They have no significant relationship with the company other than their board membership.

Independent third-party audits Conducted by or on behalf of another organization. The request comes from a regulator, customer, or other outside entity.

Indicators of compromise (IoCs) The telltale signs that an attack has taken place and may include file signatures, log patterns, and other evidence left behind by attackers.

Industrial control system (ICS) A form of computer-management device that controls industrial processes and machines. ICSs are used across a wide range of industries, including manufacturing, fabrication, electricity generation and distribution, water distribution, sewage processing, and oil refining. There are several forms of ICS, including distributed control systems (DCSs), programmable logic controllers (PLCs), and supervisory control and data acquisition (SCADA).

Information classification The process of determining what information is accessible to what parties and for what purposes.

Information security policy A document that provides high-level authority and guidance for the security program.

Information security policy framework A framework that contains a series of documents designed to describe the organization's cybersecurity program.

Infrared sensors Rely on infrared light, or heat radiation. They look for changes in infrared radiation in a room or space and alert when that change occurs.

Infrastructure as a service (IaaS) A model of cloud computing that utilizes virtualization; clients pay an outsourcer for the resources used.

Infrastructure as code (IaC) The process of managing and provisioning computer datacenters through machine-readable definition files.

Inherent risk The original level of risk that exists before implementing any controls.

Initialization vector (IV) A nonce used by numerous cryptography solutions to increase the strength of encrypted data by increasing the randomness of the input.

Injection vulnerability A kind of vulnerability that attackers use to break through a web application and gain access to the systems supporting that application. These vulnerabilities allow an attacker to supply some type of code to the web application as input and trick the web server into either executing that code or supplying it to another server to execute.

Inline Network devices have network traffic pass through them.

Inline CASB solution Cloud Access Security Broker solutions that physically or logically reside in the connection path between the user and the service.

Input validation Checking, scanning, filtering, or sanitizing input received from users (especially over the Internet) before processing the received input.

Insecure protocols Many of the older protocols used on networks in the early days of the Internet were designed without security in mind. They often failed to use encryption to protect usernames, passwords, and the content sent over an open network.

Insider attacks An attack that occurs when an employee, contractor, vendor, or other individual with authorized access to information and systems uses that access to wage an attack against the organization.

Insider threats Employees, contractors, and other insiders may pose a security risk and that everyone should be alert for anomalous behavior.

Integer overflow A variant of a buffer overflow where the result of an arithmetic operation attempts to store an integer that is too large to fit in the specified buffer.

Integrated penetration testing Combines aspects of both offensive and defensive testing to provide a comprehensive assessment of an organization's security posture.

Integrity Ensures that there are no unauthorized modifications to information or systems, either intentionally or unintentionally.

Integrity metric (I) A metric that describes the type of information alteration that might occur if an attacker successfully exploits the vulnerability.

Intellectual property Includes trade secrets, which encompass proprietary business information that provides a company with a competitive edge, such as formulas, manufacturing processes, strategies, or any other confidential information.

Intellectual property (IP) theft Risk that occurs when a company possesses trade secrets or other proprietary information that, if disclosed, could compromise the organization's business advantage.

Intent/motivation Attackers also vary in their motivation and intent.

Interactive testing Combines static and dynamic testing, analyzing the source code while testers interact with the application through exposed interfaces.

Intermediate CAs The offline CA uses the root certificate to create subordinate intermediate CAs that serve as the online CAs used to issue certificates on a routine basis.

Internal audits Performed by an organization's internal audit staff and are typically intended for internal audiences.

Internal monitoring Includes internal audits, reviews, and checks to ensure that the organization is following its policies and meeting legal requirements.

Internal risks Risks that originate from within the organization.

Internal threat actor Threat actors that come from within our own environments.

International Organization for Standardization (ISO) An organization that defines and maintains computer, networking, and technology standards, along with more than 13,000 other international standards for business, government, and society.

Internet of Things (IoT) A broad term that describes network-connected devices that are used for automation, sensors, security, and similar tasks.

Internet Security Association and Key Management Protocol (ISAKMP) A framework for key exchange and authentication. It defines how to authenticate the system you want to communicate with, how to create and manage SAs (security assertions), and other details necessary to secure communication.

Intimidation A key principle that relies on scaring or bullying an individual into taking a desired action.

Intranet Web (or similar) services set up in a private network to be accessed internally only.

Intrusion detection system (IDS) A product that automates the inspection of audit logs and real-time system events. IDSs are generally used to detect intrusion attempts, but they can also be employed to detect system failures or to rate overall performance.

Intrusion prevention system (IPS) A tool designed to detect the attempts to gain unauthorized access and prevent the attempts from becoming successful.

Invoice scams A type of fraud that sends fake invoices to organizations in hopes of receiving payment.

IoT *See* Internet of Things.

`ipconfig/ifconfig` Tools that show the current TCP/IP network configuration for the host they are run on.

IPS *See* intrusion prevention system.

IPSec Internet Protocol Security is a suite of security protocols used to encrypt and authenticate IP traffic.

ISAKMP *See* Internet Security Association and Key Management Protocol.

ISO *See* International Organization for Standardization.

ISO 27001 A standard covering security control objectives for information systems.

ISO 27002 A standard describing the actual controls that an organization may implement to meet cybersecurity objectives.

ISO 27701 A standard that contains guidance for managing privacy controls.

ISO 31000 A standard that provides guidelines for risk management programs.

Isolation A concept that ensures that any behavior will affect only the memory and resources associated with the process. Also, the act of keeping something separated from others. Isolation can be used to prevent commingling of information or disclosure of information.

J

Jailbreaking Takes advantages of vulnerabilities or other weaknesses in a mobile device's operating system to conduct a privilege escalation attack and root the system, providing the user with more access than is typically allowed.

Job rotation A means by which an organization improves its overall security by rotating employees among numerous job positions. Job rotation serves two functions. First, it provides a type of knowledge redundancy. Second, moving personnel around reduces the risk of fraud, data modification, theft, sabotage, and misuse of information.

Journaling Creates a log of changes that can be reapplied if an issue occurs.

Jump server A secured and monitored system used to provide a way to securely operate in security zones with different security levels.

Just-in-time (JIT) permissions Permissions that are granted and revoked only when needed.

K

Kerberos An authentication protocol developed at MIT that uses tickets for authentication.

Kerckhoffs' principle Also known as Kerckhoffs' assumption, states that a cryptographic system should be secure even if everything about the system, except the key, is public knowledge.

Key escrow Systems have a third party store a protected copy of the key for use in an emergency.

Key exchange The secure distribution of the secret keys required to operate the algorithms. The three main methods are offline distribution, public key encryption, and the Diffie–Hellman key exchange algorithm.

Key management practices The security measures taken by cryptosystem users and administrators to protect the security of the keying material.

Key management systems Used to store keys and certificates as well as to manage them centrally.

Key performance indicators (KPIs) Quantitively measure the vendor's performance.

Key recovery Organizations may have a formal key recovery policy that specifies the circumstances under which a key may be retrieved from escrow and used without a user's knowledge.

Key risk indicators (KRIs) Metrics used to measure and provide early warning signals for increasing levels of risk.

Key space The range of values that are valid for use as a key for a specific algorithm. A key space is defined by its key length.

Keyloggers Programs that capture keystrokes from a keyboard, although keylogger applications may also capture other input such as mouse movement, touchscreen inputs, or credit card swipes from attached devices.

Knowledge-based authentication (KBA) An authentication option that is frequently used for password resets in the form of security questions.

Known environment tests Tests performed with full knowledge of the underlying technology, configurations, and settings that make up the target.

Known plain text This attack relies on the attacker having pairs of known plain text along with the corresponding ciphertext.

KPIs See key performance indicators (KPIs).

L

Lateral movement *See* pivoting.

LDAP *See* Lightweight Directory Access Protocol.

LDAPS See Secure Lightweight Directory Access Protocol.

Least privilege Granting the least amount of authorization to users so that they can perform their work tasks but nothing else.

Legacy systems Outdated systems that often do not receive security updates.

Legal hold A notice that informs an organization that they must preserve data and records that might normally be destroyed or modified in the course of their normal operations.

Level of sophistication/capability Threat actors vary greatly in their level of cybersecurity sophistication and capability.

Licensing limitations May curtail the bandwidth consumed by the vulnerability scanner or the number of scans that may be conducted simultaneously.

Lighting One of the most commonly used forms of perimeter security controls. The primary purpose of lighting is to discourage casual intruders, trespassers, prowlers, and would-be thieves who would rather perform their malicious activities in the dark.

Lightweight Directory Access Protocol (LDAP) Directory services like LDAP are commonly deployed as part of an identity management infrastructure and offer hierarchically organized information about the organization.

Lightweight Directory Access Protocol (LDAP) injection attack A variation of a SQL injection attack; however, the focus of the attack is on the backend of an LDAP directory service rather than a database server.

Lightweight Extensible Authentication Protocol (LEAP) A Cisco proprietary alternative to the Temporal Key Integrity Protocol (TKIP) for Wi-Fi Protected Access (WPA). This was developed to address deficiencies in TKIP before the 802.11i/WPA2 system was ratified as a standard.

Likelihood of occurrence The measurement of probability that a threat will become realized within a specific period of time.

Load balancer A system used to spread or distribute network traffic load across several network links or network devices. The purpose of load balancing is to obtain more optimal infrastructure utilization, minimize response time, maximize throughput, reduce overloading, and eliminate bottlenecks.

Load balancing Makes multiple systems or services appear to be a single resource, allowing both redundancy and increased ability to handle loads by distributing it to more than one system.

Local file inclusion attack A kind of file inclusion attack that seeks to execute code stored in a file located elsewhere on the web server.

Lock One of the most common physical security controls.

Log reviews Log reviews from servers, applications, network devices, and other sources that might contain information about possible attempts to exploit detected vulnerabilities.

Logic bombs Functions or code placed inside other programs that will activate when set conditions are met.

Logical segmentation This is done using software or settings rather than a physical separation using different devices.

Loop prevention A protection that focuses on detecting loops and then disabling ports to prevent the loops from causing issues.

M

Malicious updates Code signing protects against malicious updates, where an attacker attempts to deploy a fake patch that actually undermines the security of an application or operating system.

Malware Describes a wide range of software that is intentionally designed to cause harm to systems and devices, networks, or users.

MAM *See* Mobile application management.

Managed power distribution units (PDUs) Devices that provide intelligent power management and remote control of power delivered inside server racks and other environments.

Managed security service providers (MSSPs) When MSPs offer security services, they are called MSSPs.

Managed service providers (MSPs) Services organizations that provide information technology as a service to their customers. MSPs may handle an organization's IT needs completely, or they may offer focused services such as network design and implementation, application monitoring, or cloud cost management.

Managerial controls Sometimes called procedural controls, managerial controls are controls that are implemented through processes like awareness, training, and oversight.

Mandatory access control (MAC) An access control mechanism that uses security labels to regulate subject access to objects. Implementations include using a hierarchical MAC environment, a compartmentalized MAC environment, and a hybrid MAC environment.

Mandatory vacations A security policy that requires all employees to take vacations at least annually so that their work tasks and privileges can be audited and verified. This helps with detection of abuse, fraud, or negligence.

Man-in-the-middle attack *See* On-path attack.

Masking The process that partially redacts sensitive information by replacing some or all sensitive fields with blank characters.

Master service agreements (MSAs) Agreements that provide an umbrella contract for the work that a vendor does with an organization over an extended period of time.

Maturity model An approach that describes the current and desired positioning of an organization along a continuum of progress.

MCM *See* Mobile content management.

MD5 A cryptographic hashing algorithm that produces a fixed length hash. MD5 has been supplanted by SHA-1, but remains in use in some circumstances.

MDM *See* Mobile device management.

Mean time between failures (MTBF) A measure of the reliability of a system. It is the expected amount of time that will elapse between system failures.

Mean time to repair (MTTR) The average amount of time to restore a system to its normal operating state after a failure.

Measured boot A boot process that provides a trusted log of all components like drivers and other components loaded during a boot process.

Measured service Everything you do in the cloud is measured by the provider.

Memorandum of agreement (MOA) A formal document that outlines the terms and details of an agreement between parties, establishing a mutual understanding of the roles and responsibilities in fulfilling specific objectives.

Memorandum of understanding (MOU) A letter written to document aspects of the relationship.

Memory injection The technique of maliciously inserting information into memory. It is the primary goal of a buffer overflow attack.

Memory pointer An area of memory that stores an address of another location in memory.

Message digest The unique output value derived from the content of a message through hashing.

Meta-feature A term in the Diamond Model that refers to start and end time stamps, phase, result, direction, methodology, and resources, which are used to order events in a sequence known as an activity thread, as well as for grouping events based on their features.

Metadata The results of a data mining operation on a data warehouse.

MFA *See* Multifactor authentication.

Microservices Cloud service offerings that provide very granular functions to other services, often through a function-as-a-service model. These microservices are designed to communicate with each other in response to events that take place in the environment.

Microwave sensors Use a baseline for a room or space that is generated by detecting normal responses when the space is at a baseline.

Minimum Security Standards for Electronic Information A document that divides information into four different data protection levels (DPLs) and then describes what controls are required, optional, and not required for data at different levels, using a detailed matrix.

Misinformation Incorrect information, often resulting from getting facts wrong.

Mitigation *See* Risk mitigation.

MOA See Memorandum of agreement (MOA).

Mobile application management (MAM) Application management allows enterprise control of applications. These features may include deploying specific applications to all devices, limiting which applications can be installed; remotely adding, removing, or changing applications and settings for them, or monitoring application usage.

Mobile content management (MCM) Ensures secure access and control of organizational files, including documents and media on mobile devices.

Mobile device management (MDM) MDM tools manage mobile devices like Android and iOS phones, tablets, and other similar systems.

Mobile metadata A type of metadata that is collected by phones and other mobile devices as they are used.

Monitoring procedures Procedures that describe how the organization will perform security monitoring activities, including the possible use of continuous monitoring technology.

MOU *See* Memorandum of understanding.

MSP *See* Managed service provider.

MSSP *See* Managed security service provider.

MTBF *See* Mean time between failures.

MTTR *See* Mean time to repair.

Multifactor authentication (MFA) Authentication that relies on two or more distinct authentication factors from the set of something you know, something you have, and something you are.

Multiparty risk Risk that impacts more than one organization.

Multitenancy The fact that many different users share resources in the same cloud infrastructure.

N

NAC *See* Network access control.

NAT gateway A common network tool that uses network address translation (NAT) to allow a single external public IP to serve many devices behind the router.

Nation-state attacks Attacks by nation-state actors hacking into either foreign governments or corporations.

NDA See Nondisclosure agreement.

`netcat` A network utility that can be used to read from and write to network connections, allowing many actions such as port scanning, shell access, and other purposes. Often called a network Swiss Army knife.

`netstat` A tool that provides network statistics by protocol; includes information about the local address and the remote address for each connection, as well as the state of TCP connections.

Network access control (NAC) Focuses on determining whether a system or device should be allowed to connect to a network.

Network-attached storage (NAS) A bulk storage device connected to a network.

Network interface card (NIC) A physical device that connects computers and other network equipment to the transmission medium.

Network segmentation *See* Segmentation.

Network Time Security (NTS) A secure version of the Network Time Protocol (NTP). It does not protect the time data. Instead, it focuses on authentication to make sure that the time information is from a trusted server and has not been changed in transit.

Neutral risk appetites Organizations that take a balanced approach and are willing to take on moderate levels of risk to achieve steady growth and returns.

Next-Generation Firewalls (NGFWs) Firewalls that incorporate contextual information into their decision-making process, including information about users, applications, and business processes. They are the current state-of-the-art in network firewall protection and provide a variety of other advanced capabilities, but they also cost more than simpler products.

NGFW *See* Next-generation firewall.

`nmap` A penetration testing tool capable of performing port scans, ping sweeps, banner grabbing, network discovery, and more.

Nondisclosure agreements (NDAs) Require that employees protect any confidential information that they gain access to in the course of their employment.

Nonrepudiation Someone who performed some action, such as sending a message, cannot later deny having taken that action.

nslookup A tool that performs a lookup of an IP address to return a domain name, or a domain name to return an IP address, and looks up specific DNS information like MX (mail server), A, and other DNS records.

NTS *See* Network time security.

O

OAuth Open Standard for Authorization, a common method for authorizing websites or applications to access information.

Obfuscation *See* Data obfuscation.

Object storage Provides customers with the ability to place files in buckets and treat each file as an independent entity that may be accessed over the web or through the provider's API.

OCSP *See* Online Certificate Status Protocol.

Offboarding The process of removing a staff member from an organization, often as part of a termination process. Disabling accounts, removing rights and privileges, and reclaiming organizational property and devices are all part of common offboarding processes.

Offensive penetration testing A proactive approach where security professionals act as attackers to identify and exploit vulnerabilities in an organization's networks, systems, and applications.

Offline CA Used to protect the root certificate. Certificate authorities must carefully protect their own private keys to preserve their trust relationships.

Off-site storage Storing data off the premises, usually in a secure location.

Onboarding The process of adding a new individual to an organization. Creating user accounts, providing accounts and privileges, and issuing required equipment, keys, access cards, and other necessities.

On-demand self-service computing Cloud resources are available when and where you need them.

On-path attack An attack that occurs when someone/something that is trusted intercepts packets and retransmits them to another party.

On-site storage Storage options like tape drives, storage area networks (SANs), and network-attached storage (NAS) devices.

One-time passwords (OTPs) Passwords that can be used for only one attempted logon, after which they become invalid. One-time passwords are often implemented via software or hardware token.

One-time risk assessment Offers the organization a point-in-time view of its current risk state.

Ongoing operations and maintenance A software development phase, including patching, updating, minor modifications, and other work that goes into daily support.

Online Certificate Status Protocol (OCSP) A real-time facility for verifying the validity of a digital certificate and confirming that it has not been revoked by the issuing certificate authority.

OpenID An open SSO standard maintained by the OpenID Foundation that can be used in conjunction with OAuth or on its own.

Open source intelligence (OSINT) Threat intelligence that is acquired from publicly available sources.

Open vulnerability and assessment language (OVAL) A language for specifying low-level testing procedures used by checklists.

Open Worldwide Application Security Project (OWASP) The home of a broad community of developers and security practitioners, and it hosts many community-developed standards, guides, and best practice documents, as well as a multitude of open source tools.

Operational controls The mechanisms and procedures used to ensure or maintain security on a day-to-day basis.

Operational risk The risk to the organization's ability to carry out its day-to-day functions.

Order of volatility Documents what data is most likely to be lost due to system operations or normal processes.

Organized crime Appears in any case where there is money to be made, and cybercrime is no exception.

OSINT *See* Open source intelligence.

OTP *See* One-time password.

Out-of-band management A management interface that is not accessed in the same way that the device or system is used. For network devices, this may be a separate port and VLAN, or a serial console.

Out-of-cycle logging An indicator of compromise that occurs when events are logged at times they typically do not occur, potentially demonstrating malicious activity.

Over-the-shoulder code review A code review methodology that relies on a pair of developers, with one writing code while explaining what they are doing and the other developer watching and reviewing. Programmers are required to switch roles on a recurring basis.

OWASP *See* Open Worldwide Application Security Project.

P

PaaS *See* Platform as a service.

Package monitoring Involves keeping track of all the third-party libraries or packages used in your organization, understanding what they do, and being aware of any potential vulnerabilities they may have.

Pair programming An agile software development technique that places two developers at one workstation.

PAM *See* Privileged access management (PAM).

Parallel processing exercises Move processing to a hot site or alternate/backup system or facility to validate that the backup can perform as expected.

Parameter pollution A technique that works by sending a web application more than one value for the same input variable.

Partially known environment Tests are a blend of known and unknown environment testing. A partially known environment test may provide some information about the environment to the penetration testers without giving full access, credentials, or configuration details.

Partition encryption This is similar to full-disk encryption but targets a specific partition of a hard drive instead of the entire disk.

Pass-around code review A code review process that relies on email or other distribution methods to distribute code for review.

Pass-the-hash attack A form of replay attack that takes place against the operating system rather than a web application.

Passive reconnaissance A technique that seeks to gather information without directly engaging with the target.

Password complexity A security setting that enforces a specific requirement, such as requiring specific character types, not allowing dictionary words, or other attempts to ensure the password is not easily cracked.

Password cracker A tool used against a password file to attempt to recover the original password from a hashed or encrypted file.

Password history A list of passwords that have already been used.

Password key Hardware device that supports things like one-time passwords, public-key cryptography for security certificates, and various security protocols like FIDO (Fast Identity Online) and U2F.

Password management Educates users about the organization's password standards and the importance of not reusing passwords across multiple sites.

Password policy A document that specifies requirements for password length, complexity, reuse, and similar issues.

Password reuse Repeating the use of a password, often on unrelated systems. In the event of a breach, password reuse means multiple systems or services could be breached using the same account and password.

Password spraying attack An attack in which the attacker uses the same password against many different accounts, then uses another password against many accounts, continuing to attempt breaches until their goal is met or they are unable to log in.

Password standards Set forth requirements for password length, complexity, reuse, and similar issues.

Password vaulting Commonly used as part of PAM environments to allow users to access privileged accounts without needing to know a password. It often allows privileged credentials to be checked out as needed while creating a logged, auditable event related to the use of the credentials.

Password vaults Software solutions that store, manage, and secure passwords and other information, allowing users to use strong passwords without memorizing dozens or hundreds of individual complex passwords.

Passwordless authentication An authentication method that relies on something you have—security tokens, one-time password applications, or certificates—or something that you are, like biometric factors.

Patch management A program that ensures that relevant patches are applied to systems. Ideally, patches are evaluated, tested, and deployed, and systems are audited to verify that the patches are applied and not removed.

Patching procedures Procedures that describe the frequency and process of applying patches to applications and systems under the organization's care.

`pathping` A Windows tool that traces the route to a destination while providing information about latency and packet loss.

Pattern matching A mechanism of action used by data loss prevention (DLP) systems that watches for the telltale signs of sensitive information.

Payment Card Industry Data Security Standard (PCI-DSS) Standard that prescribes specific security controls for merchants who handle credit card transactions and service providers who assist merchants with these transactions.

PCI DSS *See* Payment Card Industry Data Security Standard.

PEAP *See* Protected Extensible Authentication Protocol.

Penetration testing An activity used to test the strength and effectiveness of deployed security measures with an authorized attempted intrusion attack. Penetration testing should be performed only with the consent and knowledge of the management staff.

Perfect forward secrecy A technology where layers of encryption prevent nodes in the relay chain from reading anything other than the specific information they need to accept and forward the traffic.

Performance monitoring A central component of vendor monitoring.

Permission authorization States that subjects can use only permissions that their active role is allowed to use.

Permission creep Occurs when users take on new roles or are granted new permissions based on tasks they are doing. Over time, this tends to result in users accruing a broader set of permissions that may not match their current role.

Permission restrictions Limit access to resources based on the user's role or level of authorization.

Persistence The attempts of attackers to gain persistent access by ensuring they have ongoing access to a system.

Personally identifiable information (PII) Any data item that is linked back to the human from whom it was gleaned.

Pharming A phishing practice that uses malicious code on compromised systems to send unsuspecting users to malicious websites.

PHI *See* Protected health information.

Philosophical/political beliefs attacks Attacks are motivated by ideological or political reasons, such as promoting a particular cause or ideology.

Phishing A form of social engineering in which you ask someone for a piece of information that you are missing by making it look as if it is a legitimate request. Commonly sent via email.

Phishing simulation A training that sends users fake phishing messages to test their skills.

Physical controls Measures used to restrict physical access and prevent direct contact with systems or areas within a facility to protect assets and resources.

Physical isolation The idea of separating devices so that there is no connection between them. Also known as air-gapped design.

Physical penetration testing Focuses on identifying and exploiting vulnerabilities in an organization's physical security controls. This can include breaking into buildings, bypassing access control systems, or compromising surveillance systems.

Physical security standards Establish the guidelines for securing the physical premises and assets of the organization.

PII *See* Personally identifiable information (PII).

`ping` A utility used to troubleshoot a connection to test whether a particular IP address is accessible.

Pivoting A phase of the penetration test that occurs as the attacker uses the initial system compromise to gain access to other systems on the target network.

Plain text or plaintext Nonencrypted data.

Platform as a service (PaaS) A cloud service model in which the consumer can deploy tools using a platform but does not manage or control any of the underlying cloud infrastructure.

Platform diversity Diversity of technologies and vendors as a way to build resilience into an infrastructure.

Playbook Describes the actions that the organization's incident response team will take when specific types of incidents occur.

Pointer dereferencing The application follows the pointer and accesses the memory referenced by the pointer address.

Policy A document that defines the scope of security needs of an organization, prescribes solutions to manage security issues, and discusses the assets that need protection and the extent to which security solutions should go to provide the necessary protection.

Policy administrator Executes decisions made by a policy engine.

Policy-driven access control A core concept for Zero Trust policy engines that relies on policies as they make decisions that are then enforced by the security administrator and policy enforcement points.

Port mirror A tool that sends a copy of all the traffic sent to one switch port to another switch port for monitoring.

Port security A network device setting that attempts to prevent unauthorized devices from connecting to the network using MAC address filtering.

Potentially unwanted programs (PUPs) Programs that may not be wanted by the user but that are not as dangerous as other types of malware.

Predictive analysis The use of data to attempt to predict events, used in a security context to identify potential compromises and attacks.

Pressure sensors Detect a change in pressure. They may be used when an organization needs to detect an object being moved or when someone is moving through an area using a pressure plate or pad.

Pretexting When a person claiming to be someone else convinces someone to give up sensitive or personal information.

Preventive controls A type of access control that is deployed to thwart or stop unwanted or unauthorized activity from occurring.

Privacy notice A document that outlines privacy commitments.

Private cloud A cloud delivery model owned and managed internally.

Private key cryptography *See* Symmetric key cryptography.

Privilege escalation The result when users obtain access to a resource that they wouldn't normally be able to access. Common privilege escalation attack methods include running a program with Set User ID (SUID) or Set Group ID (SGID) permissions in Linux or Unix operating systems, or by temporarily becoming another user (via `su` or `sudo` in Unix/Linux or `RunAs` in Windows). It can also be done purposefully by an attacker seeking full access.

Privileged access management (PAM) A tool that can be used to handle the administrative and privileged accounts.

Privileged account Like the root account or members of the wheel group on Linux and Unix systems, and the Windows default Administrator account.

Privileges required metric (PR) A metric that describes the type of account access that an attacker would need to exploit a vulnerability.

Procedure In the context of security, a detailed step-by-step how-to document describing the actions necessary to implement a specific security mechanism, control, or solution.

Production environment This is the live system. Software, patches, and other changes that have been tested and approved move to production.

Protected cable distribution Physical security measures used to ensure that wiring and cables remain secure and that breaches of security are reported to responsible parties.

Protected Extensible Authentication Protocol (PEAP) A protocol that encapsulates EAP methods within a TLS tunnel that provides authentication and potentially encryption.

Protected health information (PHI) Data item that includes medical records maintained by health-care providers and other organizations that are subject to the Health Insurance Portability and Accountability Act (HIPAA).

Provenance A term describing the validity and history of data or a device, used to determine if it is trustworthy.

Provisioned When an account is created.

Proxy server A type of server that makes a single Internet connection and services request on behalf of many users. Proxies may be forward or reverse proxies.

PSK Preshared key, WPA-2's authentication method for encrypted personal (non-enterprise) networks.

Public cloud A cloud delivery model available to others.

Public key algorithms *See* Asymmetric key algorithms.

Public key cryptosystems Rely on pairs of keys assigned to each user of the cryptosystem.

Public key infrastructure A hierarchy of trust relationships. These trusts permit combining asymmetric cryptography with symmetric cryptography along with hashing and digital certificates, giving hybrid cryptography.

Purpose limitation The concept that that information should only be used for the purpose that it was originally collected and that was consented to by the data subjects.

Push notification Messages sent to a user to inform them of an event, in this case an authentication attempt.

Q

QoS See Quality of service (QoS).

Qualitative risk assessment A kind of risk assessment that substitutes subjective judgments and categories for strict numerical analysis, allowing the assessment of risks that are difficult to quantify.

Quality assurance (QA) The process of ensuring that software or code meets quality standards through testing and other validation processes.

Quality of service (QoS) A collection of technologies that provide the ability to balance network traffic and prioritize workloads.

Quantitative risk assessment A kind of risk assessment that uses numeric data in the analysis, resulting in assessments that allow the straightforward prioritization of risks.

Quantum computing An emerging field that attempts to use quantum mechanics to perform computing and communication tasks.

Quarantine A term often associated with malware or compromise. A quarantined device or file is placed in a location where it cannot do further harm.

R

RA *See* Registration authority.

Race condition A situation that occurs when the security of a code segment depends on the sequence of events occurring within the system.

Radio frequency identification (RFID) A technology that uses electromagnetic or electrostatic coupling in the radio frequency (RF) portion of the electromagnetic spectrum to identify a specific device. Each RFID tag includes a unique identifier so that when a nearby antenna/transceiver activates the tag, it transmits that identifier back to the antenna where that value is recorded or used to trigger some kind of action. For example, most modern toll-road systems use RFID devices that drivers attach to the windshield of their car, and each time a device is "read" by an antenna, the vehicle owner's toll balance is incremented by the cost of that transit. RFID devices may also be used to track individuals (carrying tags), equipment (bearing tags), and so forth, within the premises of an enterprise for security monitoring.

Radio frequency identification (RFID) cloning Attacks work by cloning an RFID tag or card.

RADIUS *See* Remote authentication dial-in user service.

Rainbow tables Easily searchable database of precomputed hashes using the same hashing methodology as the captured password file.

Ransomware Software that demands payment before restoring the data or system infected.

Real-time operating system (RTOS) *See* RTOS.

Recovery point objective (RPO) A measure of how much loss can be accepted by the organization when a disaster occurs. RPO is the maximum amount of time that can elapse between your backups, thus determining how much data could be lost in a disaster.

Recovery time objective (RTO) The amount of time in which you think you can feasibly recover function in the event of a disruption.

Recurring risk assessment Performed at regular intervals and are meant to track the evolution of risks over time, monitor changes in the risk profile, and ensure that risk management practices are adapting to new threats and vulnerabilities.

Red team A term used to describe a penetration testing team that attempts to break into systems; the aggressor team.

Redundancy The implementation of secondary or alternate solutions or the means to perform work tasks or accomplish IT functions.

Refactoring Restructuring an existing program or application.

Reflected denial-of-service attacks The spoofed IP address causes a legitimate service to conduct the attack, making it harder to know who the attacker is. When combined into a reflected and amplified denial-of-service attack, this can be a powerful combination that is difficult to stop and even more difficult to track down.

Reflected input When a vulnerable website is fed script commands through form fields in such a manner as to trick the site, and the input is reflected back to a visitor as if it were original and legitimate content.

Reflected XSS Reflected cross (X) site scripting commonly occurs when an application allows reflected input.

Registration authorities (RAs) RAs assist certificate authorities with the burden of verifying users' identities prior to issuing digital certificates.

Regulated information Includes any data that is governed by laws or regulations.

Regulatory requirements Requirements created by regulations and laws applicable to an organization.

Related key attack This is like a chosen plain-text attack, except the attacker can obtain ciphertexts encrypted under two different keys. This is a useful attack if you can obtain the plain text and matching ciphertext.

Relative operating characteristic (ROC) ROC compares the FRR (False rejection rate) against the FAR (false acceptance rate) of a system, typically as a graph.

Relying party (RP) RP has a similar meaning to a service party. An RP will require authentication and identity claims from an identity provider.

Remote-access VPN A type of VPN commonly used for traveling staff and other remote workers.

Remote Authentication Dial-in User Service (RADIUS) A centralized authentication authorization and accounting service, often used for VPN connections.

Remote file inclusion A kind of file inclusion attack that allows the attacker to go a step further and execute code that is stored on a remote server.

Remote wipe Capabilities used when a device is lost or stolen, or when the owner is no longer employed by the organization.

Replication Focuses on using either synchronous or asynchronous methods to copy live data to another location or device.

Reporting on controls Provides a common standard to be used by auditors performing assessments of service organizations with the intent of allowing the organization to conduct an external assessment instead of multiple third-party assessments and then sharing the resulting report with customers and potential customers.

Reputation Describes services and data feeds that track IP addresses, domains, and hosts that engage in malicious activity.

Reputational risk The risk that the negative publicity surrounding a security breach causes the loss of goodwill among customers, employees, suppliers, and other stakeholders.

Request forgery An attack that exploits trust relationships and attempts to have users unwittingly execute commands against a remote server.

Residual risk The risk that remains after an organization implements controls designed to mitigate, avoid, and/or transfer the inherent risk.

Resilience A component of availability that determines what type and level of potential disruptions the service or system can handle without an availability issue.

Resource exhaustion The situation in which systems consume all the memory, storage, processing time, or other resources available to them, rendering the system disabled or crippled for other uses.

Resource policies Policies offered by cloud providers that customers use to limit the actions that users of their accounts may take.

Resource reuse Occurs when cloud providers take hardware resources that were originally assigned to one customer and reassign them to another customer.

Resources/funding Threat actors vary in the resources available to them.

Responsiveness The ability of the system or service to respond in a timely manner as desired or required to function as designed.

Restoration order The order in which systems and services should be restored in the event of a disaster to ensure proper restoration and to avoid service dependency issues.

Retention Retention may be required for legal purposes with set retention periods determined by law, or it may be associated with a legal case due to a legal hold. Retention may also serve business purposes or have a compliance or audit component.

Retina scan An example of a biometric factor, which is a behavioral or physiological characteristic that is unique to a subject. The blood vessel pattern at the back of the eyeball is used to establish identity or provide authentication.

Revenge attacks Motivated by a desire to get even with an individual or organization by embarrassing them or exacting some other form of retribution against them.

Reverse proxy A type of proxy that is placed between servers and clients and that is used to help with load balancing and caching of content.

RFID *See* Radio frequency identification.

Rich communication services (RCS) RCS messages can help prevent data leakage from secure areas.

Right-to-audit clause A part of the contract between the cloud service and an organization, which provides either a direct ability to audit the cloud provider or an agreement to use a third-party audit agency.

Right to be forgotten Also known as the right to erasure, is a concept that has been implemented in various data protection laws, notably the European Union's General Data Protection Regulation.

Risk The seriousness of an event to an organization based on a combination of the likelihood of that event occurring and the negative impact of the event if it does occur.

Risk acceptance A risk management option that involves deliberately choosing to take no other risk management strategy and to continue operations as normal in the face of the risk.

Risk appetite An organization's willingness to tolerate risk within the environment.

Risk assessment An evaluation of how much risk you and your organization are willing to take. An assessment must be performed before any other actions, such as determining how much to spend for security in terms of dollars and labor.

Risk avoidance The process of selecting alternate options or activities that have less associated risk than the default, common, expedient, or cheap option.

Risk calculation The process of calculating the risks that exist in terms of costs, number, frequency, and so forth.

Risk event reports Focused on documenting specific risk events, such as security breaches or incidents, their impacts, and the responses taken.

Risk identification process The process of identifying the threats and vulnerabilities that exist in the operating environment.

Risk management A detailed process of identifying factors that could damage or disclose data, evaluating those factors in light of data value and countermeasure cost, and implementing cost-effective solutions for mitigating or reducing risk.

Risk management framework (RMF) A mandatory standard for federal agencies that provides a formalized process that federal agencies must follow to select, implement, and assess risk-based security and privacy controls.

Risk matrix An approach that quickly summarizes risks and allows senior leaders to quickly focus on the most significant risks facing the organization.

Risk mitigation The implementation of safeguards and countermeasures to eliminate vulnerabilities or block threats.

Risk owner An individual or entity responsible for managing and monitoring risks, including implementing necessary controls and actions to mitigate them.

Risk register The primary tool that risk management professionals use to track risks facing the organization.

Risk reporting An essential component of the risk management process that involves communicating the status and evolution of risks to stakeholders within the organization.

Risk threshold The specific level at which a risk becomes unacceptable.

Risk tolerance An organization's ability to withstand risks and continue operations without any significant impact.

Risk transference A strategy of dealing with risk in which it is decided that the best approach is to offload some of the risk through insurance, third-party contracts, and/or shared responsibility.

Risk trend analysis A reporting form that involves analyzing historical data to identify patterns or trends in the risks faced by the organization.

RMF *See* Risk management framework.

RoE *See* Rules of engagement.

Rogue wireless access point An unauthorized wireless access point on a network.

Role assignment States that subjects can use only permissions that match a role they have been assigned.

Role authorization States that the subject's active role must be authorized for the subject.

Role-based access control (RBAC) A form of nondiscretionary access control that employs job function roles to regulate subject access to objects.

Role-based training A type of training that ensures that individuals receive the appropriate level of training based on their job responsibilities.

Root cause analysis (RCA) A process used to identify the underlying cause of an event or incident. RCA often uses approaches like Five Whys, event analysis, or diagramming to help identify the root cause.

Root certificate The top-level certificate for an entire PKI that serves as the root of trust for all certificates issued by the CA.

Rootkits Software programs that have the ability to obtain root-level access and hide certain things from the operating system.

route A tool that is used to display and modify a system's routing tables.

RPO *See* Recovery point objective.

RSA public key algorithm Public key cryptosystem named after its creators, Ronald Rivest, Adi Shamir, and Leonard Adleman.

RTO *See* Recovery time objective.

RTOS (real-time operating system) A system designed to handle data and inputs as they occur.

Rule-based access control (RBAC or RuBAC) A variation of mandatory access controls. A rule-based system that uses a set of rules, restrictions, or filters to determine what can and cannot occur on the system, such as granting subject access, performing an action on an object, or accessing a resource. Firewalls, proxies, and routers are common examples of rule-based access control systems.

Rules of engagement (RoE) The rules that are agreed to for a penetration test. These rules are defined before the test starts to ensure that the test does not cause inadvertent harm or go beyond the accepted scope.

S

SaaS *See* Software as a service.

SAE See Simultaneous authentication of equals.

Salting Random data used as input for a one-way cryptographic hash to help prevent brute-force attacks against the hashes.

SAML See Security Assertion Markup Language.

Sandbox An isolated environment where potentially dangerous or problematic software can be run.

Sandboxing A security technique that provides a security boundary for applications and prevents the application from interacting with other applications. Antimalware applications use sandboxing techniques to test unknown applications. If the application displays suspicious characteristics, the sandboxing technique prevents the application from infecting other applications or the operating system.

Sarbanes–Oxley (SOX) Act A regulation that applies to the financial records of U.S. publicly traded companies and requires that those companies have a strong degree of assurance for the IT systems that store and process those records.

SASE *See* Secure access service edge.

SCADA *See* Supervisory control and data acquisition.

Scalability A principle of application resilience that says that applications should be designed so that computing resources they require may be incrementally added to support increasing demand.

Scan perspective An aspect that conducts the scan from a different location on the network, providing a different view into vulnerabilities.

Scanless A port scanner that uses third-party scanners and open source intelligence (OSINT) to gather information.

Scarcity A key principle used for social engineering in scenarios that make something look more desirable because it may be the last one available.

Scope metric (S) A metric that describes whether the vulnerability can affect system components beyond the scope of the vulnerability.

Screened subnet A network zone that contains systems that are exposed to less trusted areas.

SDLC *See* Software development life cycle.

SDN *See* Software-defined networking (SDN).

SD-WAN *See* Software-defined wide area networks (SD-WAN).

Secret Information that requires a substantial degree of protection.

Secret key cryptography *See* Symmetric key cryptography.

Secure access service edge (SASE) Combines VPNs, SD-WAN, and cloud-based security tools like firewalls, CASBs, and Zero Trust networks to provide secure access for devices regardless of their location.

Secure boot A feature of Unified Extensible Firmware Interface (UEFI) that aims to protect the operating environment of the local system by preventing the loading or installing of device drivers or an operating system that is not signed by a preapproved digital certificate. Secure boot thus protects systems against a range of low-level or boot-level malware, such as certain rootkits and backdoors.

Secure cookies Web developers can protect against cookie theft by marking cookies with the `SECURE` attribute. Secure cookies are never transmitted over unencrypted HTTP connections. Secure cookies protect against session replay attacks.

Secure email gateway (SEG) Name used to describe email security gateways.

Secure enclave A dedicated secure element that is built into Apple's system on chip (SOC) modules.

Secure Lightweight Directory Access Protocol (LDAPS) A TLS-protected version of LDAP that offers confidentiality and integrity protections.

Secure/Multipurpose Internet Mail Extensions (S/MIME) Provides the ability to encrypt and sign MIME data, the format used for email attachments.

Secure Real-Time Transport Protocol Used for voice and video to ensure communications traffic remains secure.

Secure Shell (SSH) A protocol used for remote console access to devices; a secure alternative to Telnet. SSH is also often used as a tunneling protocol or to support other uses.

Secure web gateways (SWG) Provides a layer of application security for cloud-dependent organizations. SWGs monitor web requests made by internal users and evaluates them against the organization's security policy, blocking requests that run afoul of these requirements.

Security Assertion Markup Language (SAML) An XML-based language for communication authentication and authorization details between security domains, often over web protocols. SAML is often used to provide a web-based single sign-on (SSO) solution.

Security assessments Comprehensive reviews of the security of a system, application, or other tested environment.

Security audits Use many of the same techniques followed during security assessments but must be performed by independent auditors.

Security awareness Security awareness programs help ensure the employees and other stakeholders are aware of their information security responsibilities and that those responsibilities remain top-of-mind.

Security Content Automation Protocol (SCAP) An effort by the security community, led by the National Institute of Standards and Technology (NIST), to create a standardized approach for communicating security-related information. This standardization is important to the automation of interactions between security components.

Security controls The safeguards or countermeasures used to address security vulnerabilities to reduce or manage risk.

Security groups A feature that defines permissible network traffic.

Security guards Used in areas where human interaction is either necessary or helpful. Guards can make decisions that technical control systems cannot, and they can provide additional capabilities by offering both detection and response capabilities.

Security incidents A violation, or imminent threat of a violation, of a security policy or practice within the organization.

Security information and event management (SIEM) A security system or appliance used for monitoring and analysis of log and security data.

Security key A hardware device that supports things like one-time passwords, public key cryptography for security certificates, and various security protocols like (FIDO) and Universal Second Factor (U2F).

Security orchestration, automation, and response (SOAR) Platforms provide many opportunities to automate security tasks that cross between multiple systems.

Security tests Verify that a control is functioning properly.

Security training Ensures that users in an organization understand the risks associated with your computing environment and their role in minimizing those risks.

Security zones Physical or virtual network segments or other components of an infrastructure that are able to be separate from less secure zones through logical or physical means.

SED *See* Self-encrypting drive.

SEG *See* Secure email gateway.

Segmentation The act of subdividing a network into numerous smaller units. These smaller units, groupings, segments, or subnetworks (*subnets*) can be used to improve various aspects of the network. Segmentation can boost performance, reduce congestion, compartmentalize communication problems (such as broadcast storms), and provide security improvements through traffic isolation. Segments can be created by using switch-based VLANs, routers, or firewalls (as well as combinations of all of these).

Self-encrypting drive (SED) A drive with encryption capabilities built in.

Self-signed certificates For use inside an organization that operates an internal CA, saving the expense of obtaining certificates from a third-party CA.

Semi-authorized attackers Hackers who fall somewhere between white- and black-hat hackers.

Sender Policy Framework (SPF) An email authentication technique that allows organizations to publish a list of their authorized email servers. SPF records are added to the DNS information for your domain, and they specify which systems are allowed to send email from that domain. Systems not listed in SPF will be rejected.

Separation of duties A set of policies designed to reduce the risk of fraud and prevent other losses in an organization.

Server-based scanning An approach to vulnerability scanning that relies on servers rather than local agents.

Serverless computing An approach that does not expose customers to the actual server instances executing their code.

Server-side request forgery An attack that exploits a vulnerability but rather than tricking a user's browser into visiting a URL, they trick a server into visiting a URL based on user-supplied input.

Service account This type of account is associated with applications and services.

Service disruption attacks Attacks seek to take down or interrupt critical systems or networks, such as banking systems or health-care networks.

Service level agreements (SLAs) Written contracts that specify the conditions of service that will be provided by the vendor and the remedies available to the customer if the vendor fails to meet the SLA.

Service organization control reports (SOCs) SOC reports define two SOC levels and three types of SOC report (SOC 1, 2, and 3) that provide information about controls. SOC Type I controls describe the systems and controls and assess those controls, whereas SOC Type II reports describe the effectiveness of the controls in addition to the design of the controls.

Service provider (SP) Provides services to users whose identities have been attested to by an identity provider and then performs the requested function.

Session hijacking An attack that occurs when a malicious individual intercepts part of a communication between an authorized user and a resource and then uses a hijacking technique to take over the session and assume the identity of the authorized user.

Session Initiation Protocol Secure (SIPS) Used for voice and video to ensure communications traffic remains secure.

Session replay attack An attack that captures portions of a session to play back later to convince a host that it is still talking to the original connection.

Shadow IT Dedicated employees often seek to achieve their goals and objectives through whatever means allows them to do so. Sometimes, this involves purchasing technology services that aren't approved by the organization.

Shared responsibility model An operating environment that divides responsibilities between one or more service providers and the customers' own cybersecurity teams.

Shimming A technique used by attackers without access to the driver source code, which takes a legitimate driver and wraps a malicious driver around the outside of it.

Short Message Service (SMS) Also known as text messages, a method of sending messages via cellular networks.

Shoulder surfing Watching someone when they enter their username, password, or sensitive data.

Sideloading The process of transferring files to a mobile device, typically via a USB connection, a MicroSD card, or Bluetooth in order to install applications outside of the official application store.

Signage Signs placed in visible locations as part of organization processes or security.

Signature-based detection The process used by antivirus software to identify potential virus infections on a system.

Simulation exercises Simulation exercises are used to practice security processes and procedures, and attempt to emulate an actual event in a safe way to provide useful information and feedback.

Simultaneous authentication of equals (SAE) An authentication method in WPA-3 that relies on a secure password-based authentication and password-authenticated key agreement to prevent brute-force attacks like those that would be used against preshared keys.

Simple Network Management Protocol (SNMP) Used to monitor and manage network devices.

Simple Network Management Protocol (SNMP) trap When a device configured to use SNMP encounters an error, it sends a message known as an SNMP trap. Unlike other SNMP traffic, SNMP traps are sent to an SNMP manager from SNMP agents on devices when the device needs to notify the manager. SNMP traps include information about what occurred so that the manager can take appropriate action.

Single loss expectancy (SLE) The cost associated with a single realized risk against a specific asset. The SLE indicates the exact amount of loss an organization would experience if an asset were harmed by a specific threat. SLE = asset value ($) * exposure factor (EF).

Single point of failure (SPOF) Any one item, element, or pathway that could cause significant downtime or system failure if broken, offline, or overloaded.

Single sign-on (SSO) SSO systems allow a user to log in with a single identity and then use multiple systems or services without reauthenticating.

SIPS *See* Session Initiation Protocol Secure.

Site survey A formal assessment of wireless signal strength, quality, and interference using an RF signal detector.

Site-to-site VPN A VPN that connects to networks, rather than connecting a system to a remote network.

Situational awareness Updates users on the security threats facing the organization and how they can recognize suspicious activity.

SLA *See* Service level agreement.

SLE *See* Single loss expectancy.

Smartcard Uses an embedded chip. Both contactless and physical chip reader-capable cards as well as hybrid cards are broadly deployed, and cryptographic smartcards often have the ability to generate key pairs on the card itself.

S/MIME *See* Secure/Multipurpose Internet Mail Extensions.

Smishing A phishing technique that uses phishing via SMS (text) messages and vishing or phishing via telephone.

SMS *See* Short Message Service.

Sn1per An automated scanning tool that combines multiple tools for penetration testers, including reconnaissance via WhoIs, DNS, `ping`, port scanning and enumeration, Metasploit and `nmap` automation, and brute-forcing to attempt to automatically gain access to targets.

Snapshot A backup of a virtual machine.

SNMP *See* Simple Network Management Protocol.

SNMP trap *See* Simple Network Management trap.

Social engineering Train users to be skeptical of unsolicited communications, especially those that create a sense of urgency or require sensitive information.

Software as a service (SaaS) A derivative of platform as a service that provides on-demand online access to specific software applications or suites without the need for local installation (or even local hardware and operating system requirements in many cases).

Software compliance/licensing risk Risk that occurs when an organization licenses software from a vendor and intentionally or accidentally runs afoul of usage limitations that expose the customer to financial and legal risk.

Software-defined network (SDN) A network that is controlled and configured using code and software.

Software-defined visibility (SDV) A code-defined visibility infrastructure.

Software-defined wide area network (SD-WAN) A virtual wide area network design that can combine multiple connectivity services for organizations.

Software development life cycle (SDLC) Describes the steps in a model for software development throughout its life.

Something you are Relies on a physical characteristic of the person who is authenticating themselves. Fingerprints, retina scans, voice prints, and even your typing speed and patterns are all included as options for this type of factor.

Something you have Includes a smartcard, USB or Bluetooth token, or another object or item that is in your possession.

Something you know Includes passwords, PINs, or the answer to a security question.

Somewhere you are Sometimes called a location factor, this is based on your current location. GPS, network location, and other data can be used to ensure that only users who are in the location they should be can authenticate.

SOW *See* Statement of work.

SOX Act *See* Sarbanes–Oxley Act.

Spam Unwanted, unsolicited email sent in bulk.

SPAN A tool that sends a copy of all the traffic sent to one switch port to another switch port for monitoring and combining traffic from multiple ports to a single port for analysis.

Spanning Tree Protocol (STP) Detects loops and disables ports to prevent the loops from causing issues.

Spear phishing Phishing aimed at specific individuals or groups.

SPF *See* Sender Policy Framework.

Spiral A software development life cycle model that moves through four phases—identification, design, build, and evaluation—in a repeated cycle until completed.

Split knowledge For sensitive keys, consider providing two different individuals with half of the key. They then must collaborate to re-create the entire key.

Split-tunnel VPN A virtual private network (VPN) that only sends traffic intended for systems on the remote trusted network through the VPN tunnel.

Spoliation of evidence Intentionally, recklessly, or negligently altering, destroying, fabricating, hiding, or withholding evidence relevant to legal matters.

Sprint A short working session lasting from a few days to a few weeks in the agile software development methodology.

Spyware Software programs that work—often actively—on behalf of a third party.

SQLi *See* SQL injection attack.

SQL injection (SQLi) attack The attacker might send a very unusual-looking request to the web server containing SQL commands.

SRTP *See* Secure Real-Time Protocol.

SSH *See* Secure Shell.

SSH keys Cryptographic representations of identity that replace a username and password.

SSO *See* Single sign-on.

SSRF *See* Server-side request forgery.

Staging environment A transition environment for code that has successfully cleared testing and is waiting to be deployed into production.

Stalkerware A type of spyware used to illicitly monitor partners in relationships.

Standards Documents that define compulsory requirements for the homogenous use of hardware, software, technology, and security controls. They provide a course of action by which technology and procedures are uniformly implemented throughout an organization. Standards are tactical documents that define steps or methods to accomplish the goals and overall direction defined by security policies.

Stateful firewall Pays attention to the state of traffic between systems. They can make a decision about a conversation and allow it to continue once it has been approved rather than reviewing every packet.

Stateless firewall Filters every packet based on data such as the source and destination IP and port, the protocol, and other information that can be gleaned from the packet's headers.

Statement of work (SOW) Contains project-specific details and references the master service agreement (MSA).

Static code analysis Analyzing by reviewing the code for an application.

Static testing Evaluates the security of software without running it by analyzing either the source code or the compiled application.

Storage area network (SAN) A secondary network (distinct from the primary communications network) used to consolidate and manage various storage devices.

Storage segmentation Can be used to keep personal and business data separate.

Stored procedures SQL statements written and stored on the database that can be called by applications.

Stored/persistent XSS Stores cross-site scripting code on a remote web server in an approach.

STP *See* Spanning Tree Protocol.

Strategic risk The risk that an organization will become less effective in meeting its major goals and objectives as a result of the breach.

Stream ciphers Operate on one character or bit of a message (or data stream) at a time.

Subject Subjects are typically people, applications, devices, systems, or organizations.

Subject alternative names (SANs) Allow you to specify additional items (IP addresses, domain names, and so on) to be protected by the single certificate.

Substitution cipher A cipher that uses an encryption algorithm to replace each character or bit of the plain-text message with a different character, such as a Caesar cipher.

Supervisory control and data acquisition (SCADA) An industrial control system (ICS) unit that can operate as a standalone device, can be networked with other SCADA systems, or can be networked with traditional IT systems. Most SCADA systems are designed with minimal human interfaces. Often, they use mechanical buttons and knobs or simple LCD screen interfaces (similar to what you might have on a business printer or a GPS navigation device). However, networked SCADA devices may have more complex remote-control software interfaces.

Supply chain analysis Vital in understanding the risks associated with the vendor's supply chain. Includes assessing the vendor's suppliers and understanding the interdependencies and risks that could impact the vendor's ability to deliver products or services.

Supply chain attack A kind of attack that attempts to compromise devices, systems, or software before it even reaches the organization.

Symmetric key cryptography Any cryptographic algorithm that uses the same key to encrypt and decrypt. DES, AES, and Blowfish are examples.

T

Tabletop exercise An exercise that involves individuals sitting around a table with a facilitator discussing situations that could arise and how best to respond to them.

Tailgating Following someone through an entry point.

Tap Network device that replicates traffic for inspection.

`tcpdump` A command-line packet capture tool available by default.

`tcpreplay` An open source tool used to edit and replay network traffic.

Technical constraints May limit the frequency of scanning. The scanning system may only be capable of performing a certain number of scans per day, and organizations may need to adjust scan frequency to ensure that all scans complete successfully.

Technical controls Controls that rely on technology.

Terminal Access Controller Access-Control System Plus (TACACS+) A commercial alternative to RADIUS owned by Cisco. There are three versions of TACACS: the original TACACS, XTACACS (extended TACACS), and TACACS+. TACACS integrates the authentication and authorization processes. XTACACS keeps the authentication, authorization, and

accounting processes separate. TACACS+ improves XTACACS by adding two-factor authentication. TACACS+ is the most commonly used of the three.

Test environment Where the software or systems can be tested without impacting the production environment.

TheHarvester An open source intelligence gathering tool that can retrieve information like email accounts, domains, usernames, and other details using LinkedIn; search engines like Google, Bing, and Baidu; PGP servers; and other sources.

Threat A potential occurrence that may cause an undesirable or unwanted outcome for an organization or a specific asset.

Threat hunting Cybersecurity professionals engaged in threat hunting seek to adopt the attacker's mindset and imagine how hackers might seek to defeat an organization's security controls. Threat hunters search the organization's technology infrastructure for the artifacts of a successful attack.

Threat intelligence The set of activities and resources available to cybersecurity professionals seeking to learn about changes in the threat environment.

Threat maps A geographic view of threat intelligence.

Threat scope reduction A key component in Zero Trust design. Limiting the scope of what a subject can do or what access to a resource allows limits what can go wrong if an issue does occur.

Threat vectors The path or means by which an attack can gain access to a target in order to cause harm. This is also known as the attack vector.

Time-based one-time password (TOTP) Devices or applications that generate passwords at fixed time intervals, such as every 60 seconds. Also known as synchronous dynamic password tokens.

Time-of-check-to-time-of-use (TOCTTOU or TOC/TOU) A race condition that occurs when a program checks access permissions too far in advance of a resource request.

Time-of-day restrictions Limit when activities can occur.

Token A physical device that may generate a code, plug in via USB, or connect via Bluetooth or other means to present a certificate or other information.

Tokenization The process of replacing sensitive values with a unique identifier using a lookup table.

Tool-assisted code reviews A code review process that relies on software or other tools to manage and assist the code review process.

Top Secret Information that requires the highest degree of protection.

TOTP *See* Time-based one-time password.

TPM *See* Trusted Platform Module.

`traceroute` A Linux utility used to determine the network path between two systems. Windows systems use the similar `tracert` command.

`tracert` A Windows utility used to determine the network path between two systems. Linux systems use the similar `traceroute` command.

Training and transition A software development phase ensuring that the end users are trained on the software and that the software has entered general use.

Transmission Control Protocol/Internet Protocol (TCP/IP) A suite of network protocols used to transfer information between systems in a standardized format. TCP/IP is the primary mechanism used to transport data on modern networks.

Transparent data encryption (TDE) TDE encrypts the entire database.

Transposition cipher A cipher that uses an encryption algorithm to rearrange the letters of a plain-text message to form the ciphertext message.

Trigger Viruses typically have both a trigger, which sets the conditions for when the virus will execute, and a payload, which is what the virus does, delivers, or the actions it performs.

Trojan Any application that masquerades as one thing in order to get past scrutiny and then does something malicious. One of the major differences between Trojan horses and viruses is that Trojan horses tend not to replicate themselves.

True negative report The negative report is accurate.

True positive report The positive report is accurate.

Trust A key principle that, much like familiarity, relies on a connection with the individual they are targeting. Unlike familiarity, which relies on targets thinking that something is normal, and thus familiar, social engineers who use this technique work to build a connection with their targets so that they will take the actions that they want them to take.

Trusted Automated eXchange of Intelligence Information (TAXII) TAXII is intended to allow cyberthreat information to be communicated at the application layer via HTTPS.

Trusted Platform Module (TPM) A specification for a cryptoprocessor as well as the chip in a mainboard supporting this function. A TPM chip is used to store and process cryptographic keys for the purposes of a hardware-supported or -implemented hard drive encryption system.

Two-person control A concept that is similar to separation of duties but with an important difference: instead of preventing the same person from holding two different privileges that are sensitive when used together, two-person control requires the participation of two people to perform a single sensitive action.

Type I error *See* False rejection rate (FRR).

Type I hypervisor A hypervisor that provides virtualization by running directly on bare-metal hardware.

Type II error *See* False acceptance rate (FAR).

Type II hypervisor A hypervisor that provides virtualization by running as an application supported by a host operating system.

Typosquatting Creating domains that are based on the misspelling of another.

U

UEM *See* Unified endpoint management.

Ultrasonic sensors Used in applications where proximity detection is required.

Unauthorized attackers Hackers with malicious intent.

Unclassified Information that does not meet the standards for classification under the other categories.

Unencrypted password A password that has not been hashed or otherwise secured and is stored or sent in plain text.

Unified endpoint management (UEM) UEM tools combine mobile devices, desktops and laptops, and many other types of devices in a single management platform.

Unified threat management (UTM) A security device that includes traditional functions of a firewall such as packet filtering and stateful inspection. It is able to perform packet inspection techniques, allowing it to identify and block malicious traffic. It can filter malware using definition files and/or allow lists and deny lists. It also includes intrusion detection and/or intrusion prevention capabilities. Also known as next-generation firewall.

Uninterruptible power supply (UPS) A device that can provide short-term power, usually by using batteries.

Unit testing A method of testing software. Each unit of code is tested independently to discover any errors or omissions and to ensure that it functions properly. Unit testing should be performed by the development staff.

Unknown environment Tests are intended to replicate what an attacker would encounter. Testers are not provided with access to or information about an environment, and instead, they must gather information, discover vulnerabilities, and make their way through an infrastructure or systems like an attacker would.

Unskilled attackers A term for people who use hacking techniques but have limited skills.

Unvalidated redirect An attacker can submit malicious data or content directly to the target of the redirect if the redirect is not validated.

UPS *See* Uninterruptible power supply.

Urgency A key principle that relies on creating a feeling that the action must be taken quickly due to some reason(s).

URL redirection URL redirection can take many forms, depending on the vulnerability that attackers leverage, but one of the most common is to insert alternate IP addresses into a system's hosts file. The hosts file is checked when a system looks up a site via DNS and will be used first, making a modified hosts file a powerful tool for attackers who can change it. Modified hosts files can be manually checked, or they can be monitored by system security antimalware tools that know the hosts file is a common target. In most organizations, the hosts file for the majority of machines will never be modified from its default, making changes easy to spot.

USB on-the-go (OTG) Allows devices to act as hosts for USB external devices like cameras or storage.

User acceptance testing (UAT) A software development phase that ensures that the users of the software are satisfied with its functionality.

User accounts Can run the gamut from basic access to systems, devices, or applications to power users with broad rights and privileges.

User interaction metric (UI) A metric that describes whether the attacker needs to involve another human in the attack.

Username The most commonly used means of claiming an identity.

UTM *See* Unified threat management.

V

Validated redirects The process of ensuring that redirects are coming from the expected redirection page or site through one of a variety of technical means.

VDI *See* Virtual desktop infrastructure.

Vein recognition A technology that uses scanners that can see the pattern of veins, often in a user's finger.

Version control A feature allowing the tracking of changes and the rollback of code to earlier versions when required.

Vertical scaling Increases the capacity of existing servers by using more powerful hardware or systems.

Video surveillance A common form of physical security control, allowing security practitioners and others to observe what is happening in real time and to capture video footage of areas for future use when conducting investigations or for other reasons.

Virtual desktop infrastructure (VDI) A VDI provides users with a desktop hosted on a server. Users can typically access the desktop from any device, including desktop computers and mobile devices. Virtual desktops can be persistent (meaning that they retain changes made by the user) or nonpersistent (meaning that the desktop reverts to its original state after the user logs off). It is sometimes called a virtual desktop environment (VDE).

Virtual IP (VIP) The IP that a load balancer presents to systems that represents the service it provides.

Virtual machine (VM) A software simulation of a computer within which a process executes. Each virtual machine has its own memory address space, and communication between virtual machines is securely controlled.

Virtual machine (VM) escape The process of breaking out of the constraints of a virtual machine environment to attack or compromise the host system or software.

Virtual machine (VM) sprawl An issue that occurs when virtual machine users create virtual machine instances and then forget about them or abandon them, leaving them to accrue costs and accumulate security issues over time.

Virtual private clouds (VPCs) A "datacenter in the cloud," a VPC is used in Infrastructure as a Service (IaaS) environments as the network that is defined for an organization as their cloud environment.

Virtual private network (VPN) VPNs are used to create a secure network channel.

Virtualization Emulating one or more physical computers on the same host.

Virus A program intended to damage a computer system.

Vishing Combining phishing with Voice over IP (VoIP).

VLAN A logical network segmentation implemented on switches and bridges to manage traffic. Multiple VLANs can be hosted on the same switch but are isolated as if they are separate physical networks. Cross-VLAN communications can occur only through a routing function, often provided by a multilayer switch. VLANs function like physical network segments.

Voice recognition A system that relies on patterns, rhythms, and the sounds of a user's voice itself to recognize the user.

Volume encryption Involves encrypting a set "volume" on a storage device, which could contain several folders and files.

VPC endpoint Allows the connection of VPCs to each other using the cloud provider's secure network backbone.

VPN *See* Virtual private network.

Vulnerability A weakness. It can be due to the existence of a flaw, loophole, oversight, error, limitation, frailty, or susceptibility in the IT infrastructure or any other aspect of an organization. It can also be the result of the absence of a safeguard or countermeasure or a weakness in a protection measure.

Vulnerability database A database of vulnerabilities, including information like the severity, fixes, and other information useful for both attackers and defenders.

Vulnerability feed A feed of information about vulnerabilities used by vulnerability scanners and other devices and systems to ensure that vulnerability identification and validation are current and up-to-date.

Vulnerability management A program used to detect weaknesses within an organization. Vulnerability scans and vulnerability assessments are two common elements of a vulnerability management program. Vulnerability scans are technical scans performed regularly, and vulnerability assessments are normally combined with a risk assessment.

Vulnerability scanning Identifying specific vulnerabilities in your network.

W

WAF *See* Web application firewall (WAF).

Walk-through A type of exercise that takes a team through an incident step by step.

War May be a motivation for cyberattacks.

War driving The act of using a radio wave signal detector or a wireless network detector to locate wireless networks.

War flying The expansion of war driving to the use of drones and unmanned aerial vehicles (UAVs).

Warm site A middle ground between hot sites and cold sites for disaster recovery specialists. A warm site always contains the equipment and data circuits necessary to rapidly establish operations but does not typically contain copies of the client's data.

Waterfall A software development method that uses well-defined, sequential phases.

Watering hole attacks Use websites that targets frequent to attack them.

Watermarking Systems or administrators apply electronic tags to sensitive documents; then the data loss prevention (DLP) system can monitor systems and networks for unencrypted content containing those tags.

Web application firewall (WAF) A firewall specifically designed to protect web applications.

Web filters Sometimes called content filters, they are centralized proxy devices or agent-based tools that allow or block traffic based on content rules.

Web metadata A type of metadata that is embedded into websites as part of the code of the website but that is often invisible to everyday users.

Web shell A malicious web-based shell-like interface that allows the attacker to execute commands on the server and view the results in the browser.

Whaling Phishing aimed at senior staff and organizational leadership or other high-profile targets.

What to Do if Compromised A document that lays out a mandatory process that merchants suspecting a credit card compromise must follow, typically provided by a merchant bank or credit card company.

White team Observers and judges.

Wi-Fi A wireless network operating in the 2.4 GHz and/or 5 GHz range(s).

Wi-Fi Protected Access 2 (WPA2) A revision of WPA upgrading the encryption to an AES variant known as CCMP. WPA2 can be deployed in personal mode with a pre-shared key authentication or in enterprise mode using 802.1x to leverage existing network authentication.

Wi-Fi Protected Access 3 (WPA3) The replacement for WPA2, which has been required to be supported in all Wi-Fi devices since July 2020.

Work order (WO) *See* Statement of work.

Worm A form of malicious code that is self-replicating but that is not designed to impose direct harm on host systems. The primary purpose of a worm is to replicate itself to other systems and gather information. Worms are usually very prolific and often cause a denial-of-service because of their consumption of system resources and network bandwidth in their attempt to self-replicate.

X

XaaS Anything as a Service where *X* indicates the nature of the specific service.

XDR *See* Extended detection and response.

XML Injection A variant of SQL injection, where the backend target is an XML application.

XSRF *See* Cross-site request forgery.

XSS *See* Cross-site scripting.

Z

Zero-day attacks An attack on a system that exploits vulnerabilities that are unknown to others, including the vendor.

Zero Trust Presumes that there is no trust boundary and no network edge. Instead, each action is validated when requested as part of a continuous authentication process and access is only allowed after policies are checked including elements like identity, permissions, system configuration and security status, threat intelligence data review, and security posture.